

Appendix E Phase 1 Run Pack and Capture Log

E.1 Purpose

This appendix records how the **Phase 1** runs were carried out, and records every output exactly as the model returned it.

The design behind the runs, the prompt conditions and the run protocol were described in Chapter 3, Sections 3.6 and 3.7. Also the scenario is at Appendix A, the master prompts are at Appendix B, and the requirement text is at Appendix C.

E.2 Execution

The following files with master Prompts A, B and E were run on 16 August 2026, once per model. Before any run, three prompt files were put together, one for each condition, from the prompt library, the scenario brief and the requirement extract from PCI DSS v4.0.1 standard document.

Every run followed the same steps as follows;

- The assembled file was copied whole and pasted into a single message as plain text, in a fixed order. I.e.; the master prompt instruction, then the scenario block where the condition had one, then the requirement block, then the output instruction.
- Nothing was uploaded as a file and nothing was retyped.
- Each cell ran in a fresh session, with no earlier conversation, custom instruction, project, saved memory or system prompt in force.
- The first complete response was taken, and no follow-up question was asked.
- The build string, the interface, the date and the time were noted before each output was recorded in this document.

During the execution, no run was refused and none was cut short. The three files were checked against each other before use. Prompt A and Prompt B differ only in the framing instruction and the output block; Prompt A and Prompt E differ only in the opening line and the missing scenario block; the requirement block is the same

in all three, character for character; and the word NorthPay does not appear anywhere in Prompt E.

E.3 The six cells

The six cells ran at five-minute intervals between 20:40 and 21:05 BST on 16th Aug 2026, two under each prompt condition.

Each output code names the model and the prompt behind it as shown in the following table.

Output	Model	Prompt strategy	Master prompt
P1a	ChatGPT	Standard-reference	Prompt A
P1b	ChatGPT	Compliance-framing	Prompt B
P2a	Grok	Standard-reference	Prompt A
P2b	Grok	Compliance-framing	Prompt B
P1c	ChatGPT	Control, no scenario	Prompt E
P2c	Grok	Control, no scenario	Prompt E

Table E.1: The six Phase 1 cells and the prompts.

E.4 Capture log

E.4.1 P1a — ChatGPT — Standard-reference (Prompt A)

Field	Record
Output ID	P1a
Model	ChatGPT
Prompt strategy	Standard-reference (Prompt A)
Prompt used	Master Prompt A
Instrument files	Prompt Library.docx; Requirement Text Extract PCI DSS v4.0.1 Requirements 7, 8, 10, 12.docx;

Field	Record
	Scenario Brief NorthPay.docx; Assembled prompt PROMPT-A_Standard-reference_ASSEMBLED_2026-08-16.txt
Model build / version	GPT-5.6 Sol (by Open AI)
Interface (app / API)	App
Date and time (BST)	16 Aug 2026 - 20:40 BST
Non-default settings	None
Refusal / truncation?	No

Verbatim output:

NorthPay Ltd Information Security Policy

1. Purpose, Scope and Governance

1.1 Purpose and application

PCI DSS references: 12.1.1, 12.1.2

This Information Security Policy establishes NorthPay Ltd's requirements for protecting system components and information assets that are within, connected to, or capable of affecting the security of the Cardholder Data Environment (CDE).

This Policy applies to all NorthPay personnel, contractors, third-party users, system and application accounts, and relevant third-party service providers (TPSPs) whose activities could affect the security of account data or the CDE.

The Policy shall be established, published, maintained and disseminated to all relevant personnel and, where applicable, relevant vendors and business partners. It shall be reviewed at least once every 12 months and updated whenever necessary to reflect changes to business objectives or risks to the environment.

1.2 PCI DSS scope

PCI DSS references: 12.5.1, 12.5.2

NorthPay shall maintain a current inventory of all system components within PCI DSS scope, including the function and use of each component.

NorthPay shall document and confirm its PCI DSS scope at least once every 12 months and following any significant change to the in-scope environment.

The scope validation shall include:

1. all payment data flows for authorization, settlement, disputes, chargebacks, returns and refunds relevant to NorthPay's card-not-present e-commerce channel;
2. current data-flow diagrams;

3. all locations where account data is stored, processed or transmitted, including applications, transmissions, backups and locations outside the currently defined CDE;
4. all components within the CDE, connected to the CDE, or capable of affecting its security;
5. all segmentation controls and the environments from which the CDE is segmented, together with justification for environments treated as out of scope;
6. all third-party connections providing access to the CDE; and
7. confirmation that the identified data flows, account data, components, segmentation controls and relevant third-party connections are included in scope.

For NorthPay, this scope shall include, where applicable, the online storefront and checkout page, payment-page scripts that initialise the PSP-supplied payment fields, relevant AWS components, administrative access paths, identity services, security controls, logging and monitoring systems, order-management components, settlement processes and relevant third-party services.

NorthPay does not intentionally store, process or transmit full PAN or sensitive authentication data within its own systems. This fact shall not be used to exclude a component that is connected to, or could affect the security of, the CDE.

1.3 Information security responsibilities

* PCI DSS references: 7.1.2, 8.1.2, 10.1.2, 12.1.3, 12.1.4**

The Chief Technology Officer shall be formally assigned executive responsibility for information security and the PCI DSS programme.

The Information Security Manager shall be responsible for coordinating the operation of this Policy, maintaining the security programme, coordinating PCI DSS activities, monitoring compliance and reporting material security matters to executive management.

Specific operational responsibilities for access control, identity management, authentication, logging, monitoring, third-party oversight, risk analysis, awareness and incident response shall be documented, assigned and communicated.

All personnel shall have their information security responsibilities defined, shall be made aware of those responsibilities and shall acknowledge them.

1.4 Supporting policies and procedures

PCI DSS references: 7.1.1, 8.1.1, 10.1.1

Security policies and operational procedures supporting PCI DSS Requirements 7, 8 and 10 shall be documented, kept current, actively used and made known to all affected parties.

2. Access Control

2.1 Access control model

PCI DSS references: 7.2.1, 7.2.2

NorthPay shall maintain a role-based access-control model for all in-scope system components and data resources.

Access shall be granted only where justified by business and access needs and shall be based on the individual's job classification and function. Each user, including a privileged user, shall receive only the least privileges necessary to perform assigned responsibilities.

Group membership shall reflect current job responsibilities. Groups created for completed projects or other obsolete purposes shall be removed, or their memberships and privileges revoked, where there is no continuing documented business requirement.

2.2 Access approval

PCI DSS references: 7.2.3, 8.2.4

The addition, deletion or modification of user IDs, authentication factors, group membership, privileges or other identity objects shall require appropriate authorization.

Required privileges shall be approved by authorized personnel before access is provisioned. Implemented privileges shall not exceed those specified in the documented approval.

2.3 Access reviews

PCI DSS reference: 7.2.4

All user accounts and associated privileges, including privileged and third-party/vendor accounts, shall be reviewed at least once every six months.

Each review shall:

1. confirm that the account remains required;
2. confirm that access remains appropriate to the user's current job function;
3. identify and address inappropriate or excessive access; and
4. record management acknowledgement that retained access remains appropriate.

2.4 Application and system accounts

PCI DSS references: 7.2.5, 7.2.5.1

Application and system accounts shall receive only the privileges necessary for system or application operation. Their access shall be restricted to the systems, applications and processes that specifically require their use.

Application and system account access and privileges shall be periodically reviewed at a frequency determined by a targeted risk analysis meeting Requirement 12.3.1. Reviews shall confirm that access remains appropriate, correct inappropriate access and record management acknowledgement of retained access.

2.5 Access to stored cardholder-data repositories

PCI DSS reference: 7.2.6

Where a repository of stored cardholder data exists within scope, user access shall be through applications or other programmatic methods, with permitted access and actions determined by role and least privilege. Direct access or querying shall be restricted to responsible administrators.

NorthPay shall not treat the absence of intentionally stored full PAN as grounds for weakening controls over any repository subsequently identified as containing cardholder data.

3. User Identification and Authentication

3.1 Unique identities

PCI DSS reference: 8.2.1

Every user shall be assigned a unique ID before access to an in-scope system component or cardholder data is permitted. Authentication and logging shall preserve individual accountability.

3.2 Shared and generic credentials

****PCI DSS reference: 8.2.2****

Group, shared or generic IDs and shared authentication credentials shall be prohibited except where an exceptional circumstance makes their use necessary.

Any exception shall:

1. prevent use except during the approved exceptional circumstance;
2. be limited to the time required;
3. have documented business justification;
4. receive explicit management approval;
5. require confirmation of the individual user's identity before access; and
6. preserve attribution of every action to an individual user.

3.3 Account lifecycle

****PCI DSS references: 8.2.4, 8.2.5, 8.2.6****

NorthPay shall operate a documented joiner, mover and leaver process covering in-scope accounts and authentication factors.

Access for terminated users shall be revoked immediately.

Inactive user accounts shall be removed or disabled within 90 days of inactivity.

Changes to identities, authentication factors and privileges shall be authorized and implemented only to the extent approved.

3.4 Third-party remote accounts

****PCI DSS reference: 8.2.7****

Accounts used by third parties to remotely access, support or maintain in-scope system components shall be enabled only for the period in which they are required and disabled when not in use.

Use of such accounts shall be monitored for unexpected activity.

3.5 Session inactivity

****PCI DSS reference: 8.2.8****

User sessions shall require re-authentication after more than 15 minutes of inactivity.

This requirement applies to administrative sessions and other in-scope user sessions, including relevant SaaS applications. Session configurations that permit indefinite authenticated access while a browser remains open shall not be used where Requirement 8.2.8 applies.

3.6 Authentication factors

****PCI DSS references: 8.3.1, 8.3.3, 8.3.11****

All user and administrator access to in-scope system components shall be authenticated using at least one approved factor: something the user knows, something the user has, or something the user is.

A user's identity shall be verified before any authentication factor is modified.

Physical or logical security tokens, smart cards and certificates used as authentication factors shall be assigned to individual users, shall not be shared and shall be protected so that only the intended user can use them.

3.7 Invalid authentication attempts

PCI DSS reference: 8.3.4

Authentication controls shall lock a user ID after no more than 10 invalid authentication attempts. Lockout shall continue for at least 30 minutes or until the user's identity has been confirmed.

3.8 Password establishment and reset

PCI DSS references: 8.3.5, 8.3.6, 8.3.7

Where passwords or passphrases are used:

1. first-use and reset passwords shall have a unique value and shall be changed immediately after first use;
2. passwords shall contain both alphabetic and numeric characters;
3. passwords shall contain at least 12 characters, except where a system does not support 12 characters, in which case the minimum shall be eight characters; and
4. a new password shall not be the same as any of the previous four passwords used.

NorthPay systems currently configured with a ten-character minimum shall be changed to meet the 12-character minimum wherever the system supports it.

3.9 Authentication guidance

PCI DSS reference: 8.3.8

NorthPay shall document and communicate authentication policies and procedures to users. Guidance shall address:

1. selection of strong authentication factors;
2. protection of authentication factors;
3. prohibition on reuse of previously used passwords or passphrases; and
4. changing passwords or passphrases following suspected or known compromise and reporting the incident.

3.10 Single-factor password authentication

PCI DSS reference: 8.3.9

Where a password or passphrase is the only authentication factor used for user access, NorthPay shall either require it to be changed at least every 90 days or dynamically analyse account security posture and automatically determine access to resources in real time.

3.11 Multi-factor authentication

PCI DSS references: 8.4.1, 8.4.2, 8.4.3

MFA shall be implemented for:

1. all non-console access into the CDE by personnel with administrative access;
2. all non-console access into the CDE; and
3. all remote access originating outside NorthPay's network that could access or impact the CDE.

MFA shall therefore be enforced through the identity and access architecture for all applicable in-scope access and shall not be limited to the AWS console or collaboration suite.

3.12 Application and system account authentication

PCI DSS references: 8.6.1, 8.6.2, 8.6.3

Application and system accounts capable of interactive login shall be prevented from interactive use except in an exceptional circumstance. Any such use shall be time-limited, supported by documented business justification, explicitly approved by management, subject to individual identity verification and fully attributable to an individual.

Passwords or passphrases for application and system accounts capable of interactive login shall not be hard-coded in scripts, configuration or property files, or bespoke/custom source code.

Application and system account passwords or passphrases shall be changed periodically at a frequency determined through a targeted risk analysis satisfying Requirement 12.3.1, and whenever compromise is suspected or confirmed. Their complexity shall be appropriate to the determined change frequency.

4. Logging and Security Monitoring

4.1 Logging and monitoring responsibilities

PCI DSS references: 10.1.1, 10.1.2

NorthPay shall maintain documented and current logging and monitoring procedures. Responsibilities for operating logging controls, conducting reviews, investigating anomalies and responding to control failures shall be assigned and understood.

4.2 Protection of audit logs

PCI DSS reference: 10.3.1

Read access to audit-log files and logging systems shall be restricted to personnel with a documented job-related need.

4.3 Daily log reviews

PCI DSS reference: 10.4.1

NorthPay shall review at least once daily:

1. all security events;
2. logs from system components that store, process or transmit cardholder data or sensitive authentication data;
3. logs from all critical system components; and
4. logs from servers and components performing security functions, including relevant network security controls and authentication systems.

The daily review requirement applies irrespective of normal office hours and shall be supported by procedures that ensure required reviews occur every day.

4.4 Other log reviews

PCI DSS references: 10.4.2, 10.4.2.1, 12.3.1

Logs from other in-scope system components not subject to Requirement 10.4.1 shall be reviewed periodically.

The frequency shall be established and justified by a documented targeted risk analysis satisfying Requirement 12.3.1.

Relevant administrator activity logs maintained within SaaS platforms shall be included in the applicable review arrangements.

4.5 Exceptions and anomalies

PCI DSS reference: 10.4.3

Exceptions, anomalies and suspicious activity identified through log review shall be investigated and addressed. The disposition of identified anomalies shall be documented sufficiently to demonstrate that the review resulted in appropriate action.

4.6 Audit-log retention

PCI DSS reference: 10.5.1

Audit-log history shall be retained for at least 12 months. At least the most recent three months shall be immediately available for analysis.

NorthPay shall maintain retention or archival arrangements sufficient to preserve audit logs beyond the current 90-day searchable SIEM period so that the complete minimum 12-month history is retained.

4.7 Failure of critical security controls

PCI DSS reference: 10.7.3

Failures of critical security control systems shall be responded to promptly. Response activities shall include:

1. restoration of the affected security function;
2. documentation of the start and end date and time of the failure;
3. identification and documentation of the cause and required remediation;
4. identification and remediation of security issues arising during the failure;
5. determination of whether further action is required;
6. implementation of controls to prevent recurrence; and
7. resumption of security-control monitoring.

5. Security Governance and Risk Management

5.1 Policy management

PCI DSS references: 12.1.1, 12.1.2

This Policy and its supporting policies and procedures shall have documented ownership and shall be maintained as controlled documents.

They shall be reviewed at least once every 12 months and updated as required following changes to business objectives, risks or the environment.

Obsolete roles, responsibilities and control descriptions shall be corrected as part of policy maintenance.

5.2 Acceptable use of end-user technology

PCI DSS reference: 12.2.1

NorthPay shall document and implement acceptable-use policies for end-user technologies.

Such policies shall include:

1. explicit approval by authorized parties;
2. permitted and acceptable uses; and
3. a list of hardware and software products approved for employee use.

Use of company-issued laptops and permitted use of personal devices shall be governed by these policies.

5.3 Targeted risk analyses

PCI DSS reference: 12.3.1

For every PCI DSS requirement listed in this Policy that requires NorthPay to determine a control frequency or process through targeted risk analysis, NorthPay shall document an analysis containing:

1. the assets being protected;
2. the applicable threats;
3. factors contributing to the likelihood and/or impact of each threat;
4. the resulting analysis and justification demonstrating how the selected frequency or process minimizes the likelihood and/or impact of the threat;
5. review of the analysis at least once every 12 months to determine whether it remains valid; and
6. an updated analysis where the annual review determines that an update is required.

This shall include, where applicable, analyses supporting Requirements 7.2.5.1, 8.6.3, 10.4.2.1 and 12.10.4.1.

5.4 Customized approach risk analysis

PCI DSS reference: 12.3.2

Where NorthPay meets a PCI DSS requirement using the customized approach, a targeted risk analysis shall be performed at least once every 12 months.

The analysis shall include documented evidence covering each applicable element of Appendix D, including at minimum a controls matrix and risk analysis, and shall receive senior-management approval.

5.5 Cryptographic protocols and cipher suites

PCI DSS reference: 12.3.3

NorthPay shall maintain an up-to-date inventory of all cryptographic cipher suites and protocols in use, including their purpose and locations of use.

At least once every 12 months, NorthPay shall review the inventory, actively monitor industry trends concerning the continued viability of the cryptography in use, and maintain a documented plan for responding to anticipated changes in cryptographic vulnerabilities.

The inventory shall include applicable TLS use and other cryptographic protocols used by in-scope systems and processes.

5.6 Technology lifecycle review

PCI DSS reference: 12.3.4

Hardware and software technologies used within the in-scope environment shall be reviewed at least once every 12 months.

The review shall determine whether:

1. vendors continue to provide security fixes promptly;
2. the technologies continue to support and do not preclude PCI DSS compliance;
3. relevant industry announcements, trends and vendor end-of-life plans have been identified and documented; and

4. outdated technologies require remediation.

Where remediation is required, NorthPay shall maintain a remediation plan approved by senior management.

6. Security Awareness and Personnel Controls

6.1 Security awareness programme

PCI DSS references: 12.6.1, 12.6.2

NorthPay shall implement a formal security awareness programme covering the information security policy and procedures and personnel responsibilities for protecting cardholder data.

The programme shall be reviewed at least once every 12 months and updated when necessary to reflect new threats and vulnerabilities affecting cardholder data, sensitive authentication data or personnel responsibilities.

6.2 Training and acknowledgement

PCI DSS reference: 12.6.3

All personnel shall receive security awareness training upon hire and at least once every 12 months thereafter.

Multiple communication methods shall be used. Personnel shall acknowledge at least once every 12 months that they have read and understood NorthPay's information security policy and procedures.

NorthPay shall track completion and follow up outstanding training so that the programme applies to all required personnel.

6.3 Threat awareness

PCI DSS reference: 12.6.3.1

Security awareness training shall address threats and vulnerabilities capable of affecting the security of cardholder data or sensitive authentication data, including phishing, related attacks and social engineering.

6.4 Acceptable-use awareness

PCI DSS reference: 12.6.3.2

Security awareness training shall include the acceptable use of end-user technologies established under Requirement 12.2.1.

6.5 Personnel screening

PCI DSS reference: 12.7.1

Potential personnel who will have access to the CDE shall be screened before hire, within the constraints of applicable local law, to minimize the risk of attacks from internal sources.

7. Third-Party Service Provider Management

7.1 TPSP register

PCI DSS reference: 12.8.1

NorthPay shall maintain a current list of all TPSPs with which account data is shared or that could affect the security of account data.

The register shall describe the services supplied by each TPSP and shall include relevant payment, cloud, SaaS and other service providers where those services could affect account-data security.

7.2 Written agreements

PCI DSS reference: 12.8.2

NorthPay shall maintain written agreements with every TPSP with which account data is shared or that could affect the security of the CDE.

Each agreement shall include acknowledgement by the TPSP of its responsibility for the security of account data it possesses, stores, processes or transmits on NorthPay's behalf, or to the extent that the TPSP could affect the security of NorthPay's cardholder data or sensitive authentication data.

7.3 TPSP engagement and due diligence

PCI DSS reference: 12.8.3

NorthPay shall operate an established process for engaging TPSPs. Proper security due diligence shall be completed before engagement.

A TPSP shall not be treated as approved for an in-scope service solely because a commercial contract has been signed.

7.4 Monitoring TPSP PCI DSS status

PCI DSS reference: 12.8.4

NorthPay shall implement a programme to monitor the PCI DSS compliance status of applicable TPSPs at least once every 12 months.

The monitoring outcome shall be documented and retained.

7.5 Responsibility matrix

PCI DSS reference: 12.8.5

NorthPay shall maintain information identifying:

1. PCI DSS requirements managed by each TPSP;
2. PCI DSS requirements managed by NorthPay; and
3. requirements for which responsibility is shared.

This information shall include the allocation of responsibilities between NorthPay and its PSP and other applicable TPSPs.

8. Security Incident Response

8.1 Incident response plan

PCI DSS reference: 12.10.1

NorthPay shall establish, document and maintain an incident response plan capable of immediate activation following a suspected or confirmed security incident that could impact the CDE.

The plan shall include:

1. assigned roles and responsibilities;
2. communication and contact strategies;
3. notification arrangements for payment brands and NorthPay's acquirer, at a minimum;
4. incident-specific containment and mitigation procedures;
5. business recovery and continuity procedures;
6. data-backup processes;
7. analysis of applicable legal reporting requirements;
8. coverage and response arrangements for all critical system components; and
9. reference to or inclusion of applicable payment-brand incident-response procedures.

8.2 Incident response review and testing

PCI DSS reference: 12.10.2

The incident response plan shall be reviewed at least once every 12 months, updated where required and tested at least once every 12 months.

Testing shall cover all elements required by Requirement 12.10.1, including relevant communication, containment, recovery, backup and notification procedures.

8.3 Continuous incident-response availability

PCI DSS reference: 12.10.3

NorthPay shall designate specific personnel who are available on a 24-hour-per-day, seven-day-per-week basis to respond to suspected or confirmed security incidents.

The designated arrangements shall provide coverage outside normal office and shared-mailbox monitoring hours.

8.4 Incident responder training

PCI DSS references: 12.10.4, 12.10.4.1, 12.3.1

Personnel responsible for responding to suspected or confirmed security incidents shall receive appropriate periodic training concerning their incident-response responsibilities.

The frequency of this training shall be determined and justified through a targeted risk analysis meeting Requirement 12.3.1.

8.5 Security monitoring alerts

PCI DSS reference: 12.10.5

The incident response plan shall define procedures for monitoring and responding to alerts from applicable security monitoring systems, including:

1. intrusion-detection and intrusion-prevention systems;
2. network security controls;
3. change-detection mechanisms for critical files;
4. the change- and tamper-detection mechanism for payment pages, in accordance with its PCI DSS applicability status; and
5. detection of unauthorized wireless access points.

Alerts from NorthPay's security monitoring systems shall feed into documented response arrangements capable of supporting the incident-response obligations in this Policy.

8.6 Lessons learned

PCI DSS reference: 12.10.6

Following incidents, exercises and material developments, NorthPay shall modify and evolve its incident response plan to incorporate lessons learned and relevant industry developments.

8.7 Unexpected PAN discovery

PCI DSS reference: 12.10.7

Because NorthPay does not expect full PAN to be stored within its estate, discovery of stored PAN in an unexpected location shall immediately initiate documented incident-response procedures.

Those procedures shall include:

1. determining whether the PAN should be retrieved, securely deleted or migrated into the defined CDE, as applicable;
2. determining whether sensitive authentication data is stored with the PAN;
3. identifying the source of the account data and how it reached the unexpected location; and
4. remediating the data leak, control failure or process gap that caused the data to be present.

9. Policy Compliance and Maintenance

9.1 Operational implementation

PCI DSS references: 7.1.1, 8.1.1, 10.1.1, 12.1.1

NorthPay shall support this Policy with the procedures, records and assigned responsibilities necessary for its requirements to be used in practice and understood by affected personnel and relevant third parties.

Documented controls shall reflect the actual operating environment and shall be updated when systems, responsibilities or processes change.

9.2 Review and approval

PCI DSS reference: 12.1.2

This Policy shall be reviewed at least once every 12 months and sooner where changes to NorthPay's business objectives, PCI DSS scope, systems, third-party relationships or risks make revision necessary.

The review shall confirm that ownership, responsibilities, system descriptions and control requirements remain current. Changes shall be documented and approved in accordance with NorthPay's assigned information security governance responsibilities.

E.4.2 P1b — ChatGPT — Compliance-framing (Prompt B)

Field	Record
Output ID	P1b
Model	ChatGPT

Field	Record
Prompt strategy	Compliance-framing (Prompt B)
Prompt used	Master Prompt B
Instrument files	Prompt Library.docx; Requirement Text Extract PCI DSS v4.0.1 Requirements 7, 8, 10, 12.docx; Scenario Brief NorthPay.docx; assembled prompt PROMPT-B_Compliance-framing_ASSEMBLED_2026-08-16.txt
Model build / version	GPT-5.6 Sol (by Open AI)
Interface (app / API)	App
Date and time (BST)	16 Aug 2026 - 20:45 BST
Non-default settings	None
Refusal / truncation?	No

Verbatim output:

NorthPay Ltd Information Security Policy

Policy owner: Information Security Manager

Executive accountable owner: Chief Technology Officer (CTO)

Approved by: Senior Leadership Team

Applies to: All NorthPay Ltd personnel, contractors, relevant third-party service providers (TPSPs), and systems that are in scope for, connected to, or capable of affecting the security of the cardholder data environment (CDE)

PCI DSS validation context: Merchant Level 3; SAQ A-EP

Review frequency: At least annually and following significant business, technology, payment, regulatory, or security changes

Primary PCI DSS references: Requirements 7, 8, 10 and 12 of PCI DSS v4.0.1

1. Purpose, Scope and Policy Principles

1.1 Purpose

This policy establishes the information security controls NorthPay Ltd ("NorthPay") shall use to protect its information assets and payment environment and to meet the applicable requirements of PCI DSS v4.0.1.

NorthPay shall apply security controls proportionately to its size, risk and operating model while meeting all applicable PCI DSS requirements. A control shall not be omitted solely because NorthPay does not store full payment card numbers.

****Compliance intent:**** PCI DSS requires information security to operate as an ongoing business process rather than an activity performed only before annual validation.

****PCI DSS references:**** 7.1.1, 8.1.1, 10.1.1, 12.1.1–12.1.4.

1.2 Payment environment and scope

NorthPay accepts card-not-present payments through its e-commerce website. Customers enter payment account data into fields supplied by NorthPay's payment service provider (PSP) and embedded within a checkout page served by NorthPay.

NorthPay does not intentionally receive or store full Primary Account Numbers (PANs), card verification values (CVVs) or other sensitive authentication data (SAD). Nevertheless, systems that serve, administer, secure or can alter the e-commerce payment page can affect the security of account data and shall be treated as PCI DSS in scope where applicable.

The PCI DSS scope shall therefore include, as applicable:

1. the public storefront and checkout application;
2. payment-page scripts and their deployment mechanisms;
3. production AWS systems and security services supporting the storefront;
4. administrative access paths into production;
5. relevant identity and authentication services;
6. security logging and monitoring systems;
7. relevant source-code repositories and deployment mechanisms;
8. the PSP integration and merchant portal;
9. systems supporting settlement, refunds, disputes and other payment-related processes;
10. relevant third parties and connections;
11. segmentation controls relied upon to reduce PCI DSS scope; and
12. other systems capable of materially affecting the security of the CDE.

NorthPay shall not describe a system as out of scope merely because it does not itself store PAN.

****Compliance intent:**** PCI DSS scope includes systems that can affect the security of payment account data, including e-commerce systems capable of changing payment pages.

****PCI DSS references:**** 12.5.1, 12.5.2.

1.3 UK GDPR relationship

PCI DSS and UK data protection law have different scopes. Compliance with PCI DSS does not by itself demonstrate compliance with the UK GDPR or Data Protection Act 2018.

Customer names, addresses, contact information, IP addresses, order histories, support correspondence and other information relating to identifiable customers shall be handled as personal data where applicable. Truncated card information may also form part of personal data when associated with an identifiable customer.

Where security logs, access records, incident evidence or payment-related systems contain personal data, NorthPay shall apply both this policy and its applicable UK GDPR controls, including requirements concerning security, minimisation, retention, access and breach response.

1.4 Regulatory boundary

NorthPay is an online retailer and PCI DSS merchant. This policy does not impose or imply any Financial Conduct Authority authorisation or regulatory obligation. NorthPay does not lend, offer checkout credit, hold client money or hold FCA permission.

2. Governance and Responsibilities

****PCI DSS references:**** 7.1.2, 8.1.2, 10.1.2, 12.1.1–12.1.4.

2.1 Executive accountability

The CTO is the executive accountable for information security and NorthPay's PCI DSS programme.

The CTO shall:

1. provide executive oversight and adequate resources;
2. approve material security risks and remediation plans;
3. ensure responsibilities are allocated to appropriate personnel;
4. review material PCI DSS compliance issues;
5. ensure overdue significant security findings are escalated; and
6. approve this policy and material changes to it.

2.2 Information Security Manager

The Information Security Manager is responsible for day-to-day coordination of this policy and shall:

1. maintain the PCI DSS compliance programme;
2. coordinate access reviews, risk analyses, scope reviews and evidence collection;
3. oversee security monitoring and incident response;
4. maintain required security registers;
5. coordinate security awareness activities;
6. oversee TPSP security assurance;
7. report material risks and compliance deficiencies to the CTO; and
8. arrange annual PCI DSS validation activities.

The Information Security Manager may delegate individual activities but remains responsible for verifying their completion.

2.3 Compliance Analyst

The Compliance Analyst shall support maintenance of evidence, registers, reviews, supplier records, training records, risk documentation and PCI DSS validation materials.

2.4 System and business owners

Each in-scope system shall have a named system owner. System and business owners shall:

1. determine legitimate business access requirements;
2. approve or sponsor access where authorised to do so;
3. participate in periodic access reviews;
4. maintain appropriate operating procedures;
5. support risk and technology reviews; and
6. ensure identified deficiencies are remediated.

2.5 All personnel

All personnel shall:

1. follow applicable security policies and procedures;
2. use only authorised systems, accounts and devices;
3. protect authentication factors;
4. promptly report suspected security incidents;
5. complete required security training; and
6. acknowledge their security responsibilities at least annually.

Security responsibilities relevant to a role shall be included in job descriptions or equivalent documented role descriptions.

****Compliance intent:**** Security controls need named owners. Assigning responsibility avoids important activities becoming informal or dependent upon a single individual's memory.

3. Access Control and Business Need to Know

****PCI DSS Requirement 7****

3.1 Access control model

****PCI DSS references:**** 7.1.1, 7.1.2, 7.2.1–7.2.3.

NorthPay shall operate a role-based access control model based on:

- * job function;
- * business need;
- * least privilege; and
- * separation between ordinary and privileged access where appropriate.

Access shall normally be assigned through approved identity-provider or application groups rather than individually configured permissions.

No person shall receive access merely because it may be convenient in future.

Privileged or administrative access shall only be provided where the person's duties require it. Ordinary user access shall be used for routine activities wherever technically possible.

The Information Security Manager and relevant system owners shall maintain an access-control matrix showing the approved roles or groups for material in-scope systems and the access each role provides.

****Compliance intent:**** A compromised account can only expose what that account can reach. Least privilege limits both accidental misuse and the damage an attacker can cause.

3.2 Access requests and approval

****PCI DSS references:**** 7.2.2, 7.2.3, 8.2.4.

New access and changes to existing access shall:

1. be requested through an approved, auditable process;
2. identify the person, system and access required;
3. state the business reason;
4. be approved by the person's manager and/or appropriate system owner;
5. provide no more privilege than approved; and
6. leave evidence of request, approval and implementation.

A person shall not approve their own privileged access.

3.3 Legacy and unnecessary groups

Groups that no longer support a current business function shall be removed or disabled. Membership of groups associated with completed projects shall be reviewed promptly.

The three legacy project groups created for the completed 2025 project shall be reviewed and either formally justified or removed.

3.4 User access reviews

****PCI DSS reference:** 7.2.4.**

All user accounts and privileges affecting in-scope systems, including privileged and third-party accounts, shall be reviewed at least every six months.

The review shall:

1. compare access with current job responsibilities;
2. identify excessive, obsolete and unexplained access;
3. confirm privileged access remains necessary;
4. address inappropriate access promptly; and
5. record management acknowledgement that retained access remains appropriate.

The Information Security Manager shall track completion.

3.5 Application and system accounts

****PCI DSS references:** 7.2.5, 7.2.5.1.**

Service, application, automation and other non-human accounts shall receive only permissions required for their specific function and shall be restricted to the relevant systems and processes.

A register shall identify material application and system accounts, their purpose, owner and privileges.

Their access shall be reviewed at the frequency established through a Targeted Risk Analysis (TRA) under section 7 of this policy and whenever their purpose or associated system changes.

3.6 Direct access to data repositories

****PCI DSS reference:** 7.2.6.**

NorthPay does not intentionally maintain repositories containing stored full PAN or SAD.

If stored cardholder data is introduced in future, ordinary users shall access it only through authorised applications or programmatic methods enforcing role-based least privilege. Direct querying shall be restricted to specifically authorised administrators.

Any proposal to introduce storage of full PAN or SAD requires prior review by the Information Security Manager and CTO and reassessment of PCI DSS scope before implementation.

****Compliance intent:**** Users should interact with sensitive information through controlled applications rather than unrestricted database access.

4. Identity and Authentication

****PCI DSS Requirement 8****

4.1 Unique identities

****PCI DSS references:** 8.1.1, 8.1.2, 8.2.1.**

Each user shall receive a unique identity before access to an in-scope system is permitted.

Accounts shall not be transferred between people.

NorthPay shall use its central identity provider and SSO for in-scope services wherever supported.

4.2 Shared and generic accounts

PCI DSS reference: 8.2.2.

Shared, generic or group credentials are prohibited for normal use.

Where a technical or emergency circumstance makes shared access genuinely necessary:

1. use shall be exceptional and time-limited;
2. the business reason shall be documented;
3. management shall explicitly approve the use;
4. the identity of each person receiving access shall be verified;
5. access shall be withdrawn when the exceptional need ends; and
6. logging or another control shall make actions attributable to an individual.

4.3 Joiners, movers and leavers

PCI DSS references: 8.2.4–8.2.6.

HR, managers, system owners and IT shall operate a documented joiner, mover and leaver process.

New and changed access shall be approved before implementation.

Access for terminated personnel shall be revoked immediately when termination takes effect. Where termination is involuntary or security-sensitive, access shall be revoked at or before the point the individual is informed, as directed by HR.

Changes of role shall trigger review and removal of access no longer required.

Inactive accounts shall be disabled or removed within 90 days of inactivity.

Because some SaaS access currently requires manual removal, the responsible administrator shall record completion of de-provisioning for each applicable service. NorthPay shall implement automation where proportionate and technically feasible but shall not rely on automation being available before enforcing this requirement.

Compliance intent: Dormant and former-user accounts provide attackers with access that may attract less attention than active accounts.

4.4 Third-party remote accounts

PCI DSS reference: 8.2.7.

Third-party remote-access accounts shall be disabled by default wherever technically possible and enabled only for the approved period in which access is required.

Third-party activity shall be logged and monitored for unexpected behaviour.

Persistent third-party access requires documented justification, compensating operational controls where necessary, and explicit approval from the Information Security Manager.

4.5 Session timeout

PCI DSS reference: 8.2.8.

In-scope user sessions and terminals shall require re-authentication following more than 15 minutes of inactivity.

Systems currently configured for longer or indefinite inactive sessions, including relevant administrative and order-management sessions, shall be remediated or otherwise brought into compliance where the requirement applies.

4.6 Authentication requirements

PCI DSS references: 8.3.1, 8.3.3–8.3.9, 8.3.11.

Authentication factors shall be protected as confidential security credentials.

Where passwords or passphrases are used:

1. they shall contain at least 12 characters where the system supports this, and never fewer than eight where a system technically cannot support 12;
2. they shall contain alphabetic and numeric characters where required by PCI DSS;
3. temporary or reset passwords shall be unique and require change immediately following first use;
4. the previous four passwords shall not be reused;
5. authentication shall lock after no more than ten failed attempts;
6. lockout shall last at least 30 minutes or until the user's identity has been confirmed; and
7. a suspected compromised password shall be changed immediately and reported as a security incident where appropriate.

NorthPay's central identity provider shall be configured to meet or exceed these requirements. Its current ten-character minimum shall therefore be increased to at least 12 characters.

Where passwords are the only authentication factor, passwords shall be changed at least every 90 days unless NorthPay implements a PCI DSS-compliant dynamic security-posture mechanism that determines access in real time.

NorthPay may remove unnecessary routine password expiry for accounts protected by MFA only where doing so remains consistent with the applicable PCI DSS authentication requirements and the documented authentication design.

Physical and logical tokens, certificates and other authentication factors assigned to individuals shall not be shared.

Before resetting or modifying an authentication factor, the service desk or administrator shall verify the user's identity using an approved process.

4.7 Authentication guidance

PCI DSS reference: 8.3.8.

Personnel shall receive practical guidance requiring them to:

- * use strong authentication factors;
- * protect passwords, tokens and recovery information;
- * never disclose or share authentication factors;
- * avoid password reuse;
- * reject unexpected MFA requests;
- * change credentials immediately where compromise is suspected; and
- * report suspected compromise promptly.

4.8 Multi-factor authentication

PCI DSS references: 8.4.1–8.4.3.

MFA shall be enforced for:

1. all applicable non-console access into the CDE;

2. administrative access into the CDE; and
3. remote access originating outside NorthPay's network that could access or affect the CDE.

MFA shall therefore be applied through the central identity provider to all relevant in-scope applications and administrative paths, including the order management platform, PSP merchant portal and other CDE-impacting systems where applicable, rather than only AWS and the collaboration suite.

Conditional-access rules shall prevent unmanaged personal devices from accessing systems connected to or capable of affecting the CDE.

A policy or convention alone is not sufficient where a technical enforcement mechanism is reasonably available.

****Compliance intent:**** A stolen password should not, by itself, give an attacker access to systems capable of compromising payment security.

4.9 System and application authentication

****PCI DSS references:**** 8.6.1–8.6.3.

System and application accounts shall not be used interactively unless an exceptional operational circumstance requires it.

Exceptional interactive use shall be documented, explicitly approved, limited in duration, linked to an identified individual and logged sufficiently to attribute activity.

Passwords and other reusable secrets for application and system accounts shall not be hard-coded into source code, scripts or configuration files.

Deployment and service credentials shall be held in an approved secrets-management mechanism. Repository secrets may be used only where access, audit, encryption and lifecycle controls have been assessed as suitable for the relevant risk.

Application and system passwords shall be changed immediately following suspected or confirmed compromise and otherwise at the frequency determined through a documented TRA. Credential complexity shall reflect the resulting risk and rotation frequency.

5. Logging, Monitoring and Security-Control Failures

****PCI DSS Requirement 10****

5.1 Logging responsibilities

****PCI DSS references:**** 10.1.1, 10.1.2.

The Information Security Manager is accountable for the logging and monitoring process.

Engineering shall ensure required AWS, application and security-service logging is enabled. Relevant SaaS system owners shall ensure available administrative and security audit logs are retained and reviewed.

Only personnel with a legitimate security, administration, audit or support need shall have read access to security logs.

****PCI DSS reference:**** 10.3.1.

5.2 Central logging

Where technically feasible, security-relevant logs shall be forwarded to NorthPay's SIEM or another centrally controlled repository.

This includes relevant:

- * cloud audit events;
- * network flow logs;
- * load-balancer and web security logs;
- * authentication events;
- * application security events;
- * administrative events; and
- * security-control alerts.

Where a SaaS platform cannot forward logs, NorthPay shall document this limitation and establish an equivalent documented review and retention process.

The order-management administrator log shall therefore either be integrated into central monitoring or subject to an explicitly assigned review procedure.

5.3 Daily review

PCI DSS reference: 10.4.1.

At least once every calendar day, NorthPay shall review:

1. security events;
2. applicable logs from components that store, process or transmit cardholder data;
3. logs from critical in-scope components; and
4. logs from components performing security functions, including identity, network-security and monitoring systems.

Automated alerting and correlation may perform the first-stage review, provided significant events are brought to human attention and there is evidence that the review occurred.

NorthPay is not required by this policy to operate a staffed 24-hour security operations centre. It shall, however, maintain 24/7 incident-response availability as required by section 12 and shall configure high-severity security alerts so that they can reach the designated on-call responder outside ordinary office hours.

A mailbox watched only during working hours shall not be the sole mechanism for urgent security alerts.

Compliance intent: Important security events need to be noticed quickly enough for NorthPay to act before an intrusion causes greater harm.

5.4 Other log reviews

PCI DSS references: 10.4.2, 10.4.2.1.

Logs not subject to the mandatory daily review shall be reviewed periodically.

The frequency shall be determined and justified in a TRA. Unless that analysis supports a different frequency, NorthPay shall use monthly review as its operational default.

5.5 Anomalies and exceptions

PCI DSS reference: 10.4.3.

Suspicious activity, unexplained administrative changes, repeated authentication failures, unexpected access patterns and other significant anomalies shall be investigated.

The review record shall show the event, reviewer, date, conclusion and any resulting action or incident reference.

5.6 Log protection and retention

****PCI DSS references:** 10.3.1, 10.5.1.**

Audit logs required for PCI DSS shall be retained for at least 12 months, with at least the most recent three months immediately available for analysis.

NorthPay shall therefore supplement the current 90-day searchable SIEM retention with protected archival storage sufficient to meet the 12-month requirement.

Archived logs shall be protected against unauthorised alteration or deletion and shall be retrievable within a reasonable period.

Access shall be limited by job need and logged where supported.

Where logs contain personal data, their retention and use shall also comply with UK GDPR principles. NorthPay shall document a retention purpose and period rather than retaining personal-data logs indefinitely.

****Compliance intent:**** PCI DSS requires enough historical evidence to investigate incidents that may not be discovered immediately. UK GDPR simultaneously requires NorthPay not to retain identifiable information for longer than justified.

5.7 Time consistency

NorthPay shall maintain reliable time synchronisation for systems under its control.

Where third-party platforms use different time zones, investigation procedures shall record those differences and convert timestamps consistently when reconstructing events.

5.8 Failure of critical security controls

****PCI DSS reference:** 10.7.3.**

Failures of critical security controls, including material failures of logging, monitoring, authentication, access control, web security or other security mechanisms, shall be treated promptly.

The responsible team shall:

1. restore the security function;
2. record when the failure began and ended;
3. identify and document its cause;
4. determine whether security issues occurred during the failure;
5. remediate those issues;
6. determine whether further investigation or incident response is required;
7. implement measures to prevent recurrence; and
8. confirm monitoring has resumed.

6. Information Security Governance and Acceptable Use

****PCI DSS Requirement 12****

6.1 Policy management

****PCI DSS references:** 12.1.1–12.1.4.**

This policy and supporting procedures shall be:

- * documented;
- * published in a location accessible to relevant personnel;
- * communicated to affected personnel and relevant third parties;
- * assigned an owner and approver;
- * reviewed at least every 12 months; and
- * updated following significant changes in business activities, payment architecture, technology, threats, regulation or risk.

Obsolete job titles and responsibilities shall be corrected during review.

The CTO is formally designated as the executive member responsible for information security. The Information Security Manager operates the programme on the CTO's behalf.

6.2 Policy acknowledgement

All personnel shall acknowledge at least annually that they have read and understood the information security requirements relevant to them.

Managers shall ensure that role-specific security responsibilities are documented for personnel whose work affects the CDE.

6.3 Acceptable use of end-user technology

****PCI DSS reference:** 12.2.1.**

NorthPay shall maintain an approved technology list covering company laptops, operating systems, browsers, security tools, communications software and other material end-user technologies.

Company-issued managed devices shall be used for access to systems connected to or capable of affecting the CDE unless a documented exception has been approved.

Personally owned devices may be used for approved low-risk services such as email and calendar only where NorthPay's technical controls permit. They shall not access CDE-connected or CDE-impacting systems.

Software shall not be installed or used for company business where it is prohibited by NorthPay or creates an unacceptable security risk.

Personnel shall not disable endpoint security, encryption, patching, device-management or access-control mechanisms.

Exceptions require documented approval.

****Compliance intent:**** NorthPay needs to know which devices and software can interact with its business information and prevent uncontrolled technology from becoming an indirect route into payment systems.

7. Risk Management and Targeted Risk Analyses

****PCI DSS references:** 12.3.1–12.3.4.**

7.1 Targeted Risk Analysis

NorthPay shall maintain a documented TRA for every PCI DSS control whose frequency or process is determined by NorthPay, including at least those applicable under Requirements 7, 8, 10 and 12.

Each TRA shall document:

1. the assets being protected;
2. the relevant threats;
3. factors affecting likelihood;
4. factors affecting impact;
5. the selected control frequency or process;
6. why that choice reduces risk to an acceptable level; and
7. the responsible owner.

Each TRA shall be reviewed at least every 12 months and updated where its assumptions or environment have changed.

Relevant TRAs shall include, at minimum:

- * application/system-account access reviews under 7.2.5.1;
- * application/system-account credential changes under 8.6.3;
- * periodic reviews of other logs under 10.4.2.1; and
- * periodic incident-response training under 12.10.4.1.

The Information Security Manager shall maintain a TRA register so these activities are scheduled rather than reconstructed immediately before assessment.

7.2 Customized approach

PCI DSS reference: 12.3.2.

NorthPay shall use the PCI DSS Defined Approach unless a deliberate decision is made to use the Customized Approach.

Any Customized Approach shall require:

- * the required controls matrix;
- * documented risk analysis and supporting evidence;
- * senior-management approval; and
- * review at least annually.

Use of a Customized Approach shall be discussed with NorthPay's assessor or acquirer as appropriate before being relied upon for validation.

7.3 Cryptographic inventory and review

PCI DSS reference: 12.3.3.

NorthPay shall maintain an inventory of material cryptographic protocols and cipher suites used in the in-scope environment, including:

- * purpose;
- * system or service where used;
- * protocol/version;
- * relevant certificates;
- * certificate owner or responsible service;
- * expiry/renewal mechanism where applicable; and
- * relevant key or secrets-management location.

The inventory shall include externally facing TLS and material SFTP/SSH arrangements.

It shall be reviewed at least annually against current industry and vendor guidance. NorthPay shall document anticipated deprecations or vulnerabilities and plans to replace affected technologies.

Automated certificate renewal should be used where available. Certificate expiry shall not depend solely on an individual engineer's spreadsheet where automated monitoring is reasonably available.

7.4 Technology review

PCI DSS reference: 12.3.4.

At least annually, NorthPay shall review material hardware and software used in its PCI DSS environment to confirm:

1. security fixes remain available;
2. the technology continues to support PCI DSS compliance;
3. announced end-of-life dates and significant industry concerns have been considered; and
4. outdated technologies have a documented remediation plan approved by senior management.

8. PCI DSS Scope Management

PCI DSS references: 12.5.1, 12.5.2.

8.1 System inventory

NorthPay shall maintain a current inventory of in-scope system components showing, at minimum, each component's function, owner and reason for inclusion in scope.

8.2 Annual and change-driven scope validation

The Information Security Manager shall coordinate a formal PCI DSS scope review:

- * at least once every 12 months; and
- * following significant changes affecting payment flows, infrastructure, applications, suppliers, access paths or segmentation.

The review shall identify and validate:

1. payment flows for authorisation, settlement, disputes, chargebacks and refunds;
2. e-commerce payment acceptance;
3. current data-flow diagrams;
4. all locations where account data is stored, processed or transmitted;
5. relevant backups and replicas;
6. components within, connected to or capable of affecting the CDE;
7. segmentation controls and the basis for systems treated as out of scope;
8. relevant third-party connections; and
9. all systems and flows relied upon for the SAQ A-EP validation boundary.

Changes to the payment page or PSP integration shall receive explicit PCI DSS scope and security consideration before production release.

Compliance intent: NorthPay cannot protect or assess systems that it has unintentionally omitted from its PCI DSS scope.

9. Security Awareness and Personnel Controls

PCI DSS references: 12.6.1–12.6.3.2, 12.7.1.

9.1 Security awareness programme

NorthPay shall maintain a formal security awareness programme.

Training shall be provided:

1. during onboarding; and
2. at least once every 12 months thereafter.

Annual completion is mandatory. Managers shall follow up incomplete training, and overdue completion shall be escalated.

A completion rate below 100% shall have documented exceptions for personnel who are legitimately unavailable and a defined completion date. A general completion rate of 78% is not acceptable as the completed annual control.

9.2 Training content

Training shall cover, in plain language:

- * phishing;
- * social engineering;
- * password and MFA security;
- * acceptable use of devices;
- * recognising and reporting incidents;
- * handling customer and payment-related information; and
- * individual responsibilities under this policy.

Multiple communication methods shall be used during the year, such as formal learning, security notices, short briefings or simulated exercises.

Personnel shall acknowledge the information security policy at least annually.

9.3 Role-specific training

Personnel with elevated security responsibilities shall receive training relevant to their role.

This includes:

- * administrators and engineers;
- * customer-support personnel using the PSP merchant portal;
- * finance personnel handling settlement information;
- * security and incident responders; and
- * personnel responsible for supplier assurance.

9.4 Personnel screening

PCI DSS reference: 12.7.1.

Prospective personnel who will have access to the CDE shall undergo proportionate pre-employment screening to the extent permitted by UK law.

The screening method shall reflect the role and may include identity, employment-history, reference and other lawful checks appropriate to the level of access.

10. Third-Party Service Provider Security

*PCI DSS Requirement 12.8; references:** 12.8.1-12.8.5.

10.1 TPSP register

NorthPay shall maintain a single register of TPSPs with which account data is shared or whose services could affect the security of account data or the CDE.

The register shall include:

- * supplier name;
- * service supplied;
- * business owner;
- * security relevance;
- * whether account data is stored, processed or transmitted;
- * how the supplier could affect CDE security;
- * PCI DSS status where applicable;
- * contract status;
- * most recent due-diligence/review date; and
- * next review date.

The existing suppliers touching the cloud environment shall be assessed for inclusion.

10.2 Written agreements

Applicable TPSP agreements shall contain an acknowledgement of the TPSP's responsibility for security of account data it possesses, stores, processes or transmits on NorthPay's behalf, or to the extent that its service could affect the security of NorthPay's account data or CDE.

Existing contracts lacking the necessary wording shall be addressed at renewal or sooner according to risk and PCI DSS remediation requirements.

10.3 Due diligence

Before engaging a new relevant TPSP, NorthPay shall perform proportionate security due diligence.

The review shall consider, where relevant:

- * PCI DSS compliance;
- * security certifications or independent assurance;
- * authentication and access controls;
- * incident and breach notification obligations;
- * encryption;
- * vulnerability management;
- * subcontractors;
- * data location and transfers;
- * business continuity;
- * data deletion and return; and
- * contractual security responsibilities.

A supplier shall not be treated as secure merely because it is a well-known cloud or SaaS provider.

10.4 Annual monitoring

Applicable TPSPs' PCI DSS compliance status shall be reviewed at least annually.

NorthPay shall retain appropriate evidence, such as a current Attestation of Compliance where relevant, together with the date and outcome of the review.

10.5 Responsibility matrix

NorthPay shall maintain a written PCI DSS responsibility matrix for relevant TPSPs, particularly its PSP and material cloud services.

The matrix shall identify requirements:

- * managed by NorthPay;
- * managed by the TPSP; and
- * shared between NorthPay and the TPSP.

**** Compliance intent: **** Outsourcing a service does not outsource NorthPay's responsibility to understand which party performs each PCI DSS control.

10.6 UK GDPR intersection

Where a TPSP processes customer personal data on NorthPay's behalf, supplier governance shall additionally address applicable UK GDPR processor requirements, data-processing terms, security obligations, subprocessors and international transfers.

PCI DSS evidence shall not substitute for the required data-protection assessment.

11. Incident Response

**** PCI DSS Requirement 12.10 ****

11.1 Incident Response Plan

**** PCI DSS reference: **** 12.10.1.

NorthPay shall maintain a documented Incident Response Plan capable of immediate activation for suspected or confirmed security incidents affecting or potentially affecting the CDE.

The plan shall contain:

1. named roles and deputies;
2. internal and external contact arrangements;
3. escalation criteria;
4. technical containment and mitigation procedures;
5. evidence-preservation requirements;
6. recovery and continuity procedures;
7. backup and restoration arrangements;
8. procedures for communicating with the acquirer and payment brands as applicable;
9. relevant payment-brand incident procedures;
10. legal and regulatory reporting considerations;
11. coverage of critical system components; and
12. communications procedures for customers, regulators, suppliers and other parties where required.

The Information Security Manager is Incident Response Coordinator unless unavailable, in which case a named deputy shall assume the role.

11.2 Incident reporting by personnel

All personnel shall immediately report suspected security incidents through NorthPay's designated incident-reporting channel.

Examples include:

- * suspected phishing compromise;
- * unexpected MFA prompts;
- * stolen credentials;

- * unauthorised administrative access;
- * unexplained payment-page changes;
- * malware;
- * accidental disclosure of customer information;
- * discovery of full PAN or CVV;
- * significant logging or security-control failure; and
- * suspicious supplier activity.

Personnel shall not investigate suspected card compromise independently unless incident response is part of their assigned role.

11.3 24/7 response availability

PCI DSS reference: 12.10.3.

NorthPay shall designate named personnel to be contactable on a 24/7 basis for suspected or confirmed security incidents.

This may operate as a proportionate on-call rota rather than a continuously staffed security operations centre.

The rota shall have primary and backup contacts, and high-priority security alerts shall be capable of reaching the on-call responder.

11.4 Incident-response training

PCI DSS references: 12.10.4, 12.10.4.1.

Personnel with incident-response responsibilities shall receive role-specific training.

Training frequency shall be determined through a TRA and shall also occur following significant changes to responsibilities or the response process where necessary.

11.5 Monitoring-system alerts

PCI DSS reference: 12.10.5.

The Incident Response Plan shall address alerts generated by applicable:

- * network security controls;
- * intrusion or threat-detection capabilities;
- * authentication monitoring;
- * critical-file or configuration change detection;
- * payment-page change and tamper-detection mechanisms;
- * wireless security monitoring where applicable; and
- * other critical security monitoring systems.

Alerts shall have severity levels, escalation criteria and an identified response owner.

11.6 Annual test and review

PCI DSS references: 12.10.2, 12.10.6.

The Incident Response Plan shall be reviewed and tested at least annually.

The test shall exercise all material elements of the plan, including:

- * detection;
- * escalation;
- * technical containment;

- * management decision-making;
- * recovery;
- * evidence handling;
- * acquirer/payment notification;
- * personal-data breach assessment; and
- * internal and external communications.

Lessons learned shall be documented and assigned actions, owners and due dates.

The plan shall also be updated following real incidents and relevant industry developments.

11.7 Unexpected discovery of PAN

****PCI DSS reference:** 12.10.7.**

NorthPay does not expect full PAN or SAD to exist in its systems.

Discovery of full PAN in any NorthPay-controlled system, log, file, support ticket, email, database, endpoint or other unexpected location shall therefore be treated as a security incident.

The response shall:

1. prevent unnecessary further access or copying;
2. determine whether the information can be securely deleted or must be moved into an appropriately controlled environment;
3. determine whether SAD, including CVV, is also present;
4. establish the source of the data;
5. determine how it entered the unexpected location;
6. identify affected systems and records;
7. securely remove the data where appropriate;
8. remediate the process or technical weakness that caused the occurrence; and
9. determine whether acquirer, payment-brand, regulatory or data-subject notification obligations arise.

CVV or other SAD shall not be retained after authorisation.

****Compliance intent:** Unexpected PAN is evidence that NorthPay's intended payment-data flow may have failed and must therefore trigger investigation rather than merely deletion.**

11.8 PCI DSS and UK GDPR incident coordination

A payment security incident and a personal-data breach may be the same event but create different obligations.

For every material security incident involving customer information, NorthPay shall perform two parallel assessments:

1. whether PCI DSS, contractual, acquirer or payment-brand compromise procedures require escalation or notification; and
2. whether a personal-data breach has occurred under UK GDPR.

Where UK GDPR notification criteria are met, NorthPay shall ensure the Information Commissioner's Office is notified without undue delay and, where feasible, within 72 hours after NorthPay becomes aware of the personal-data breach. Where legally required, affected individuals shall also be notified.

The Incident Response Plan shall contain the current contact route for the acquirer and an internal route to the person responsible for data-protection decisions.

The 72-hour UK GDPR assessment shall not be delayed while NorthPay waits for a complete PCI DSS forensic investigation.

Incident records shall document the decisions made under both regimes.

****Compliance intent:**** PCI DSS protects payment account data, while UK GDPR protects personal data. A single cyber incident can activate both sets of responsibilities on different timescales.

12. Personal Data, Retention and International Transfers

12.1 Data minimisation

NorthPay shall not collect or store full PAN or SAD unless a future business requirement has undergone prior security, PCI DSS and data-protection assessment and has received explicit executive approval.

Personnel shall not copy card information into tickets, email, chat, notes or order records.

Where a customer attempts to provide full payment-card details through an unsupported channel, personnel shall follow the approved handling procedure and shall not reproduce those details unnecessarily.

12.2 Retention

NorthPay shall maintain a documented retention schedule for records containing personal data.

Seven-year retention of order records may continue where justified by applicable tax and accounting requirements.

NorthPay shall establish and document proportionate retention periods for support tickets, marketing records and logs rather than retaining them indefinitely.

PCI DSS-required audit records shall be retained for the minimum period specified in section 5.6 regardless of shorter operational SIEM search periods.

12.3 Backup replication and transfers

NorthPay shall document relevant locations of backups and replicated data as part of its information asset and PCI DSS scope records.

Where personal data is transferred from the United Kingdom to another country, the responsible business owner shall ensure an applicable UK GDPR transfer mechanism or adequacy basis exists and is documented.

NorthPay's encrypted backup replication to Dublin shall be recorded in its data-processing and transfer documentation together with the applicable UK adequacy basis for transfers to the European Economic Area.

13. Security Findings, Change and Evidence

13.1 Security findings

Security findings from penetration testing, ASV scans, access reviews, incidents, supplier reviews and other assurance activities shall be recorded, assigned an owner, risk-rated and given a target remediation date.

Overdue findings shall be escalated according to risk.

The outstanding findings from the February 2026 penetration test shall remain formally tracked until remediation is completed and verified.

13.2 Security-relevant change

Changes capable of affecting the CDE, payment page, authentication, logging, network segmentation, security controls or PCI DSS scope shall receive appropriate security review before release.

Normal peer-reviewed deployment processes may satisfy this requirement where the review explicitly considers relevant security effects and produces auditable evidence.

13.3 PCI DSS evidence

Evidence supporting PCI DSS compliance shall be generated and retained as part of normal operations rather than assembled solely immediately before annual validation.

The Information Security Manager shall maintain a compliance calendar covering recurring activities including:

- * access reviews;
- * TRAs;
- * log reviews;
- * security training;
- * TPSP reviews;
- * scope validation;
- * cryptographic review;
- * technology review;
- * incident-response testing;
- * policy review;
- * ASV scans; and
- * annual validation.

Evidence shall identify the control performed, date, responsible person, outcome and resulting remediation where applicable.

****Compliance intent:**** A sustainable PCI DSS programme demonstrates that controls operated throughout the year, not merely that evidence could be produced at assessment time.

14. Exceptions and Enforcement

14.1 Exceptions

Exceptions to this policy shall not be informal.

A requested exception shall document:

1. the policy requirement affected;
2. business justification;
3. systems and information affected;
4. security risk;
5. proposed compensating or mitigating measures;
6. exception owner;
7. expiry date; and
8. required approvals.

The Information Security Manager shall review security implications. Material exceptions affecting PCI DSS compliance require CTO approval and shall not be represented as PCI DSS compliant unless the applicable PCI DSS requirements for the chosen compliance approach are satisfied.

Exceptions shall be time-limited and reviewed before renewal.

14.2 Enforcement

Failure to comply with this policy may result in removal of system access and, for personnel, disciplinary action in accordance with NorthPay's employment procedures.

Supplier non-compliance shall be handled under the applicable contract and supplier-risk process.

Deliberate concealment of a security incident, unauthorised access or circumvention of security controls shall be escalated immediately.

15. Policy Review, Approval and Records

****PCI DSS references:**** 7.1.1, 8.1.1, 10.1.1, 12.1.1, 12.1.2.

This policy shall be reviewed:

1. at least once every 12 months;
2. following a significant security incident;
3. following a significant change to NorthPay's payment architecture or PCI DSS scope;
4. following material changes to applicable PCI DSS requirements; and
5. where significant business, technology, supplier or security-risk changes make an earlier review appropriate.

The Information Security Manager shall coordinate the review.

The CTO shall approve this policy and material revisions. Approval shall be recorded and retained as compliance evidence.

Supporting procedures and registers shall be reviewed according to their defined frequencies and whenever the associated process materially changes.

15.1 Required supporting records

NorthPay shall maintain, at minimum:

- * PCI DSS scope and system-component inventory;
- * current payment and account-data flow diagrams;
- * access-control and role matrix;
- * six-monthly user access review records;
- * application/system account register and review records;
- * joiner, mover and leaver records;
- * authentication and MFA standards;
- * logging and monitoring procedures;
- * 12-month audit-log archive;
- * TRA register and completed analyses;
- * cryptographic protocol and cipher inventory;
- * technology lifecycle review;
- * approved end-user technology list;
- * security awareness and acknowledgement records;
- * relevant personnel-screening evidence;
- * TPSP register;
- * TPSP due-diligence and annual-review records;
- * PCI DSS responsibility matrix for TPSPs;
- * Incident Response Plan, contact list and test records;
- * security findings and remediation register; and
- * annual policy approval record.

These records may be maintained using proportionate tools such as controlled spreadsheets, ticketing systems, document repositories and existing cloud services. NorthPay is not required to purchase a dedicated governance platform where its existing tools provide adequate ownership, access control, version history and evidence.

15.2 Policy status

****Owner:**** Information Security Manager
****Executive accountable owner and approver:**** Chief Technology Officer
****Minimum review frequency:**** Annual
****Next review:**** No later than 12 months after approval
****Classification:**** Internal
****Applies from:**** Date of approval
****Supersedes:**** Previous information security policies covering the subject matter of this policy, unless a supporting policy or procedure is expressly retained
****Applicable PCI DSS standard:**** PCI DSS v4.0.1, Requirements 7, 8, 10 and 12

E.4.3 P2a — Grok — Standard-reference (Prompt A)

Field	Record
Output ID	P2a
Model	Grok
Prompt strategy	Standard-reference (Prompt A)
Prompt used	Master Prompt A
Instrument files	Prompt Library.docx; Requirement Text Extract PCI DSS v4.0.1 Requirements 7, 8, 10, 12.docx; Scenario Brief NorthPay.docx; assembled prompt PROMPT-A_Standard-reference_ASSEMBLED_2026-08-16.txt
Model build / version	Grok 4.5
Interface (app / API)	App
Date and time (BST)	16 Aug 2026 - 20:50 BST
Non-default settings	None
Refusal / truncation?	No

Verbatim output:

****NorthPay Ltd Information Security Policy****

****PCI DSS v4.0.1 Requirements 7, 8, 10 and 12****

****Effective Date: 16 August 2026****

****Version: 1.0****

****Owner: Information Security Manager****

****Approved by: Chief Technology Officer****

****1. Purpose and Scope****

This Information Security Policy establishes the controls required to protect system components and cardholder data in accordance with PCI DSS v4.0.1 Requirements 7, 8, 10 and 12. It applies to all personnel, system components, and third-party service providers that store, process, transmit, or could impact the security of cardholder data or the Cardholder Data Environment (CDE) of NorthPay Ltd.

****2. Requirement 7 – Restrict Access to System Components and Cardholder Data by Business Need to Know****

****2.1 Processes and Mechanisms (PCI DSS 7.1.1, 7.1.2)****

2.1.1 All security policies and operational procedures identified in Requirement 7 are documented, kept up to date, in use, and known to all affected parties.

2.1.2 Roles and responsibilities for performing activities in Requirement 7 are documented, assigned, and understood.

****2.2 Access Control Model (PCI DSS 7.2.1)****

2.2.1 An access control model is defined that grants access based on:

- Appropriate access depending on NorthPay Ltd's business and access needs;
- Access to system components and data resources based on users' job classification and functions;
- The least privileges required (for example, user or administrator) to perform a job function.

****2.3 Assignment of Access (PCI DSS 7.2.2, 7.2.3)****

2.3.1 Access is assigned to users, including privileged users, based on job classification and function and the least privileges necessary to perform job responsibilities.

2.3.2 Required privileges are approved by authorised personnel before access is granted.

****2.4 Review of User Accounts (PCI DSS 7.2.4)****

2.4.1 All user accounts and related access privileges, including third-party/vendor accounts, are reviewed at least once every six months to ensure user accounts and access remain appropriate based on job function.

2.4.2 Any inappropriate access is addressed.

2.4.3 Management acknowledges that access remains appropriate.

****2.5 Application and System Accounts (PCI DSS 7.2.5, 7.2.5.1)****

2.5.1 All application and system accounts and related access privileges are assigned and managed based on the least privileges necessary for the operability of the system or application and limited to the systems, applications, or processes that specifically require their use.

2.5.2 All access by application and system accounts and related access privileges is reviewed periodically at the frequency defined in the entity's targeted risk analysis performed according to Requirement 12.3.1.

2.5.3 The application/system access remains appropriate for the function being performed; any inappropriate access is addressed; and management acknowledges that access remains appropriate.

****2.6 Query Access to Stored Cardholder Data (PCI DSS 7.2.6)****

2.6.1 All user access to query repositories of stored cardholder data is restricted via applications or other programmatic methods, with access and allowed actions based on user roles and least privileges.

2.6.2 Only the responsible administrator(s) can directly access or query repositories of stored cardholder data.

****3. Requirement 8 – Identify Users and Authenticate Access to System Components****

****3.1 Processes and Mechanisms (PCI DSS 8.1.1, 8.1.2)****

3.1.1 All security policies and operational procedures identified in Requirement 8 are documented, kept up to date, in use, and known to all affected parties.

3.1.2 Roles and responsibilities for performing activities in Requirement 8 are documented, assigned, and understood.

****3.2 User Identification and Account Lifecycle (PCI DSS 8.2.1–8.2.8)****

3.2.1 All users are assigned a unique ID before access to system components or cardholder data is allowed.

3.2.2 Group, shared, or generic IDs, or other shared authentication credentials are only used when necessary on an exception basis and are managed as follows:

- ID use is prevented unless needed for an exceptional circumstance;
- Use is limited to the time needed for the exceptional circumstance;
- Business justification for use is documented;
- Use is explicitly approved by management;
- Individual user identity is confirmed before access to an account is granted;
- Every action taken is attributable to an individual user.

3.2.3 Addition, deletion, and modification of user IDs, authentication factors, and other identifier objects are authorised with the appropriate approval and implemented with only the privileges specified on the documented approval.

3.2.4 Access for terminated users is immediately revoked.

3.2.5 Inactive user accounts are removed or disabled within 90 days of inactivity.

3.2.6 Accounts used by third parties to access, support, or maintain system components via remote access are enabled only during the time period needed and disabled when not in use, and use is monitored for unexpected activity.

3.2.7 If a user session has been idle for more than 15 minutes, the user is required to re-authenticate to re-activate the terminal or session.

****3.3 Strong Authentication (PCI DSS 8.3.1, 8.3.3–8.3.9, 8.3.11)****

3.3.1 All user access to system components for users and administrators is authenticated via at least one of the following authentication factors: something you know (password or passphrase), something you have (token device or smart card), or something you are (biometric element).

3.3.2 User identity is verified before modifying any authentication factor.

3.3.3 Invalid authentication attempts are limited by locking out the user ID after not more than 10 attempts and setting the lockout duration to a minimum of 30 minutes or until the user's identity is confirmed.

3.3.4 If passwords/passphrases are used as authentication factors, they are set to a unique value for first-time use and upon reset and forced to be changed immediately after the first use.

3.3.5 If passwords/passphrases are used, they meet a minimum length of 12 characters (or eight characters if the system does not support 12) and contain both numeric and alphabetic characters.

3.3.6 Individuals are not allowed to submit a new password/passphrase that is the same as any of the last four passwords/passphrases used.

3.3.7 Authentication policies and procedures are documented and communicated to all users, including guidance on selecting strong authentication factors, protecting authentication factors, not reusing previously used passwords/passphrases, changing passwords/passphrases if compromise is suspected or known, and how to report the incident.

3.3.8 If passwords/passphrases are used as the only authentication factor, they are changed at least once every 90 days, or the security posture of accounts is dynamically analysed and real-time access to resources is automatically determined accordingly.

3.3.9 Where authentication factors such as physical or logical security tokens, smart cards, or certificates are used, factors are assigned to an individual user and not shared, and physical and/or logical controls ensure only the intended user can use that factor.

****3.4 Multi-Factor Authentication (PCI DSS 8.4.1–8.4.3)****

3.4.1 MFA is implemented for all non-console access into the CDE for personnel with administrative access.

3.4.2 MFA is implemented for all non-console access into the CDE.

3.4.3 MFA is implemented for all remote access originating from outside the entity's network that could access or impact the CDE.

****3.5 Application and System Accounts (PCI DSS 8.6.1–8.6.3)****

3.5.1 If accounts used by systems or applications can be used for interactive login, interactive use is prevented unless needed for an exceptional circumstance, limited to the time needed, justified in writing, explicitly approved

by management, individual user identity confirmed before access, and every action attributable to an individual user.

3.5.2 Passwords/passphrases for any application and system accounts that can be used for interactive login are not hard coded in scripts, configuration/property files, or bespoke and custom source code.

3.5.3 Passwords/passphrases for any application and system accounts are changed periodically at the frequency defined in the entity's targeted risk analysis performed according to Requirement 12.3.1 and upon suspicion or confirmation of compromise, and are constructed with sufficient complexity appropriate for the change frequency.

****4. Requirement 10 – Log and Monitor All Access to System Components and Cardholder Data****

****4.1 Processes and Mechanisms (PCI DSS 10.1.1, 10.1.2)****

4.1.1 All security policies and operational procedures identified in Requirement 10 are documented, kept up to date, in use, and known to all affected parties.

4.1.2 Roles and responsibilities for performing activities in Requirement 10 are documented, assigned, and understood.

****4.2 Protection of Audit Logs (PCI DSS 10.3.1)****

4.2.1 Read access to audit log files is limited to those with a job-related need.

****4.3 Review of Audit Logs (PCI DSS 10.4.1–10.4.3)****

4.3.1 The following audit logs are reviewed at least once daily: all security events; logs of all system components that store, process, or transmit CHD and/or SAD; logs of all critical system components; and logs of all servers and system components that perform security functions.

4.3.2 Logs of all other system components are reviewed periodically.

4.3.3 The frequency of periodic log reviews for all other system components is defined in the entity's targeted risk analysis performed according to Requirement 12.3.1.

4.3.4 Exceptions and anomalies identified during the review process are addressed.

****4.4 Retention of Audit Logs (PCI DSS 10.5.1)****

4.4.1 Audit log history is retained for at least 12 months, with at least the most recent three months immediately available for analysis.

****4.5 Failures of Critical Security Control Systems (PCI DSS 10.7.3)****

4.5.1 Failures of any critical security control systems are responded to promptly, including: restoring security functions; identifying and documenting the duration (date and time from start to end) of the security failure; identifying and documenting the cause(s) of failure and required remediation; identifying and addressing any security issues that arose during the failure; determining whether further actions are required; implementing controls to prevent the cause of failure from reoccurring; and resuming monitoring of security controls.

****5. Requirement 12 – Support Information Security with Organisational Policies and Programmes****

****5.1 Information Security Policy (PCI DSS 12.1.1–12.1.4)****

5.1.1 An overall information security policy is established, published, maintained, and disseminated to all relevant personnel, as well as to relevant vendors and business partners.

5.1.2 The information security policy is reviewed at least once every 12 months and updated as needed to reflect changes to business objectives or risks to the environment.

5.1.3 The security policy clearly defines information security roles and responsibilities for all personnel, and all personnel are aware of and acknowledge their information security responsibilities.

5.1.4 Responsibility for information security is formally assigned to a Chief Information Security Officer or other information security knowledgeable member of executive management.

****5.2 Acceptable Use Policies (PCI DSS 12.2.1)****

5.2.1 Acceptable use policies for end-user technologies are documented and implemented, including explicit approval by authorised parties, acceptable uses of the technology, and a list of products approved by the company for employee use, including hardware and software.

****5.3 Targeted Risk Analysis (PCI DSS 12.3.1–12.3.4)****

5.3.1 For each PCI DSS requirement that specifies completion of a targeted risk analysis, the analysis is documented and includes identification of the assets being protected, identification of the threat(s), identification of factors that contribute to the likelihood and/or impact of a threat being realised, resulting analysis that determines and justifies the frequency or processes defined by the entity, review of each targeted risk analysis at least once every 12 months, and performance of updated risk analyses when needed.

5.3.2 A targeted risk analysis is performed for each PCI DSS requirement that the entity meets with the customised approach, including documented evidence detailing each element specified in Appendix D, approval by senior management, and performance at least once every 12 months.

5.3.3 Cryptographic cipher suites and protocols in use are documented and reviewed at least once every 12 months, including an up-to-date inventory of all cryptographic cipher suites and protocols in use (purpose and where used), active monitoring of industry trends regarding continued viability, and documentation of a plan to respond to anticipated changes in cryptographic vulnerabilities.

5.3.4 Hardware and software technologies in use are reviewed at least once every 12 months, including analysis that the technologies continue to receive security fixes from vendors promptly, analysis that the technologies continue to support (and do not preclude) the entity's PCI DSS compliance, documentation of any industry announcements or trends related to a technology (including end-of-life plans), and documentation of a plan, approved by senior management, to remediate outdated technologies.

****5.4 PCI DSS Scope (PCI DSS 12.5.1, 12.5.2)****

5.4.1 An inventory of system components that are in scope for PCI DSS, including a description of function/use, is maintained and kept current.

5.4.2 PCI DSS scope is documented and confirmed by the entity at least once every 12 months and upon significant change to the in-scope environment. The scoping validation includes identifying all data flows for the various payment stages and acceptance channels, updating all data-flow diagrams, identifying all locations where account data is stored, processed, and transmitted, identifying all system components in the CDE, connected to the CDE, or that could impact security of the CDE, identifying all segmentation controls in use and the environment(s) from which the CDE is segmented (including justification for environments being out of scope), identifying all connections from third-party entities with access to the CDE, and confirming that all identified data flows, account data, system components, segmentation controls, and connections from third parties with access to the CDE are included in scope.

****5.5 Security Awareness Education (PCI DSS 12.6.1–12.6.3.2)****

5.5.1 A formal security awareness program is implemented to make all personnel aware of the entity's information security policy and procedures, and their role in protecting the cardholder data.

5.5.2 The security awareness program is reviewed at least once every 12 months and updated as needed to address any new threats and vulnerabilities that may impact the security of the entity's cardholder data and/or sensitive authentication data, or the information provided to personnel about their role in protecting cardholder data.

5.5.3 Personnel receive security awareness training upon hire and at least once every 12 months; multiple methods of communication are used; and personnel acknowledge at least once every 12 months that they have read and understood the information security policy and procedures.

5.5.4 Security awareness training includes awareness of threats and vulnerabilities that could impact the security of cardholder data and/or sensitive authentication data, including phishing and related attacks and social engineering.

5.5.5 Security awareness training includes awareness about the acceptable use of end-user technologies in accordance with Requirement 12.2.1.

****5.6 Personnel Screening (PCI DSS 12.7.1)****

5.6.1 Potential personnel who will have access to the CDE are screened, within the constraints of local laws, prior to hire to minimise the risk of attacks from internal sources.

****5.7 Third-Party Service Provider Oversight (PCI DSS 12.8.1–12.8.5)****

5.7.1 A list of all third-party service providers (TPSPs) with which account data is shared or that could affect the security of account data is maintained, including a description for each of the services provided.

5.7.2 Written agreements with TPSPs are maintained with all TPSPs with which account data is shared or that could affect the security of the CDE, and include acknowledgments from TPSPs that TPSPs are responsible for the security of account data the TPSPs possess or otherwise store, process, or transmit on behalf of the entity, or to the extent that the TPSP could impact the security of the entity's cardholder data and/or sensitive authentication data.

5.7.3 An established process is implemented for engaging TPSPs, including proper due diligence prior to engagement.

5.7.4 A program is implemented to monitor TPSPs' PCI DSS compliance status at least once every 12 months.
 5.7.5 Information is maintained about which PCI DSS requirements are managed by each TPSP, which are managed by the entity, and any that are shared between the TPSP and the entity.

****5.8 Incident Response (PCI DSS 12.10.1–12.10.7)****

5.8.1 An incident response plan exists and is ready to be activated in the event of a suspected or confirmed security incident. The plan includes roles, responsibilities, and communication and contact strategies (including notification of payment brands and acquirers at a minimum); incident response procedures with specific containment and mitigation activities for different types of incidents; business recovery and continuity procedures; data backup processes; analysis of legal requirements for reporting compromises; coverage and responses of all critical system components; and reference or inclusion of incident response procedures from the payment brands.

5.8.2 At least once every 12 months, the security incident response plan is reviewed and the content updated as needed, and tested, including all elements listed in Requirement 12.10.1.

5.8.3 Specific personnel are designated to be available on a 24/7 basis to respond to suspected or confirmed security incidents.

5.8.4 Personnel responsible for responding to suspected and confirmed security incidents are appropriately and periodically trained on their incident response responsibilities. The frequency of periodic training is defined in the entity's targeted risk analysis performed according to Requirement 12.3.1.

5.8.5 The security incident response plan includes monitoring and responding to alerts from security monitoring systems, including intrusion-detection and intrusion-prevention systems, network security controls, change-detection mechanisms for critical files, the change-and-tamper-detection mechanism for payment pages, and detection of unauthorised wireless access points.

5.8.6 The security incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.

5.8.7 Incident response procedures are in place to be initiated upon the detection of stored PAN anywhere it is not expected, and include determining what to do if PAN is discovered outside the CDE (including its retrieval, secure deletion, and/or migration into the currently defined CDE as applicable); identifying whether sensitive authentication data is stored with PAN; determining where the account data came from and how it ended up where it was not expected; and remediating data leaks or process gaps that resulted in the account data being where it was not expected.

****6. Policy Review and Maintenance****

This policy is reviewed at least once every 12 months and updated as needed. All personnel are required to acknowledge their understanding of this policy at least once every 12 months.

E.4.4 P2b — Grok — Compliance-framing (Prompt B)

Field	Record
Output ID	P2b
Model	Grok
Prompt strategy	Compliance-framing (Prompt B)
Prompt used	Master Prompt B
Instrument files	Prompt Library.docx; Requirement Text Extract PCI DSS v4.0.1 Requirements 7, 8, 10,

Field	Record
	12.docx; Scenario Brief NorthPay.docx; assembled prompt PROMPT-B_Compliance-framing_ASSEMBLED_2026-08-16.txt
Model build / version	Grok 4.5
Interface (app / API)	App
Date and time (BST)	16 Aug 2026 - 20:55 BST
Non-default settings	None
Refusal / truncation?	No

Verbatim output:

****NorthPay Ltd****

****Information Security Policy****

****PCI DSS v4.0.1 – Requirements 7, 8, 10 and 12****

****Document Control****

Version: 1.0

Effective date: 16 August 2026

Owner: Information Security Manager

Approver: Chief Technology Officer

Review cycle: At least once every 12 months, or sooner if the business, technology or threat landscape changes materially.

Next scheduled review: August 2027

This policy is published on the company intranet and is issued to all staff and relevant suppliers. All personnel must acknowledge that they have read and understood it at least once every 12 months.

****1. Purpose and Scope****

This policy sets out the controls NorthPay Ltd uses to protect cardholder data and the systems that support or could affect the security of that data. It addresses PCI DSS v4.0.1 Requirements 7, 8, 10 and 12.

NorthPay does not store, process or transmit full Primary Account Numbers (PANs) or Sensitive Authentication Data. Card details are captured only in fields supplied by the Payment Service Provider (PSP). The Cardholder Data Environment (CDE) therefore comprises the online storefront, checkout page, order-management platform, administrator access paths and any system that connects to or can impact those components.

Where the same systems hold customer personal data (name, address, contact details, order history, last four digits of the card, IP address and support correspondence), the controls in this policy also support NorthPay's obligations as a data controller under the UK GDPR and the Data Protection Act 2018.

This policy applies to all 61 employees, contractors and any third party that can access in-scope systems. It is deliberately proportionate to an organisation of this size.

****2. Roles and Responsibilities****

(PCI DSS 7.1.2, 8.1.2, 10.1.2, 12.1.3, 12.1.4)

- **Chief Technology Officer**: Overall executive owner of information security and the PCI DSS programme. Formally assigned responsibility for information security.
- **Information Security Manager**: Day-to-day ownership of this policy, access control, authentication, logging, monitoring, risk analysis, third-party oversight and incident response. Reports to the CTO.
- **Compliance Analyst** (3 days per week): Maintains evidence, supports reviews, tracks third-party compliance status and assists with awareness training.
- **Line managers**: Approve access requests for their teams, confirm continued need for access during periodic reviews, and ensure leavers are notified immediately.
- **All personnel**: Protect authentication factors, use systems only for authorised purposes, complete required training, and report suspected incidents without delay.
- **Head of Finance and Legal**: Co-ordinates UK GDPR breach notification and records of processing; supports legal aspects of incident response.

No separate information-security steering group exists. Security matters are raised at the monthly senior-leadership meeting by the Information Security Manager.

3. Access Control – Business Need to Know (PCI DSS Requirement 7)

Compliance intent: Only people who need access to do their jobs should have it, and only at the lowest privilege level that still lets them work. This reduces the chance that cardholder data or systems that protect it can be misused or compromised.

3.1 Access is granted strictly on the principle of least privilege and according to job classification and function. Access is never granted “just in case”.

3.2 Access requests are raised by the line manager, approved by the Information Security Manager (or CTO for privileged roles), and implemented only with the privileges stated on the approval.

3.3 All user accounts and privileges, including those of third parties and vendors, are reviewed at least every six months. The review confirms that access remains appropriate to the current job function. Any unnecessary access is removed. Management formally acknowledges that remaining access is appropriate.

3.4 Application and system accounts are assigned the minimum privileges needed for the system or process to function and are limited to the systems that require them. These accounts are reviewed periodically according to the targeted risk analysis required by Requirement 12.3.1. Management acknowledges that the access remains appropriate.

3.5 Direct query access to any repository that holds cardholder data (or data that could lead to it) is restricted to the responsible administrators only. All other users access such data only through approved applications with role-based controls.

3.6 Because NorthPay stores only the last four digits of the card together with other personal data, the same least-privilege rules also protect personal data under UK GDPR. Access to customer records is limited to those who need it for order fulfilment, support, finance or compliance.

4. Identification and Authentication (PCI DSS Requirement 8)

Compliance intent: Every person who accesses systems must be uniquely identified and strongly authenticated so that actions can be traced and unauthorised access is much harder.

4.1 Every user is assigned a unique identifier before any access is granted. Shared, group or generic accounts are forbidden except in documented, time-limited exceptional circumstances that are approved by management and that still allow actions to be attributed to an individual.

4.2 Addition, modification or deletion of user IDs, authentication factors or related objects requires prior documented approval and is implemented only with the privileges stated on that approval.

4.3 Access for terminated users is revoked immediately on the last working day (or sooner if the circumstances require). Inactive accounts are disabled or removed within 90 days of inactivity.

4.4 Third-party accounts used for remote support or maintenance are enabled only for the period required and are disabled when not in use. Their activity is monitored.

4.5 User sessions that have been idle for more than 15 minutes require re-authentication.

4.6 All access is authenticated by at least one of: something the user knows, something the user has, or something the user is.

4.7 Passwords / passphrases meet the following minimum standards:

- minimum length of 12 characters (or 8 if the system cannot support 12);
- contain both numeric and alphabetic characters;
- cannot be the same as any of the last four passwords used;
- set to a unique value on first use or reset and forced to change immediately;
- changed at least every 90 days where they are the sole authentication factor, or the account is subject to continuous risk-based analysis.

4.8 Invalid authentication attempts lock the account after no more than 10 failures for a minimum of 30 minutes or until identity is confirmed.

4.9 Multi-factor authentication (MFA) is required for:

- all non-console administrative access into the CDE;
- all non-console access into the CDE;
- all remote access from outside the NorthPay network that can reach or impact the CDE.

MFA is already enforced on the AWS console and collaboration suite; it is extended to all other in-scope systems (order-management platform, PSP merchant portal, helpdesk platform and any other system that can affect the CDE).

4.10 Authentication factors (tokens, certificates, etc.) are assigned to individuals and protected so that only the intended user can use them.

4.11 Application and system accounts that allow interactive login are treated as exceptional, time-limited, approved and attributable to an individual. Their passwords are never hard-coded and are changed periodically according to the targeted risk analysis, or immediately on suspicion of compromise.

4.12 Users are given clear guidance on choosing strong authentication factors, protecting them, never re-using passwords, and reporting any suspicion of compromise.

These authentication controls also protect personal data held in the same systems and therefore support UK GDPR security obligations.

****5. Logging and Monitoring**** (PCI DSS Requirement 10)

****Compliance intent****: We must be able to see who did what, when, and on which system, so that suspicious activity can be detected and investigated promptly and evidence retained for analysis.

5.1 Audit logs are generated for all access to system components and any data that relates to cardholder information.

5.2 Read access to audit-log files is limited to personnel with a job-related need.

5.3 The following logs are reviewed at least once daily:

- all security events;
- logs from systems that store, process or transmit cardholder data or sensitive authentication data (even though NorthPay does not store full PANs);
- logs from critical system components;
- logs from servers and components that perform security functions (firewalls, authentication services, etc.).

5.4 Logs of all other system components are reviewed periodically. The frequency is defined in the targeted risk analysis required by Requirement 12.3.1.

5.5 Exceptions and anomalies identified during review are investigated and addressed.

5.6 Audit-log history is retained for at least 12 months, with the most recent three months immediately available for analysis. (Current SIEM retention of 90 days will be extended or supplemented by offline archive to meet this requirement.)

5.7 Failures of critical security-control systems are detected, reported and responded to promptly. Response includes restoring the function, recording the duration and cause of the failure, addressing any security issues that arose, determining further actions, implementing preventive measures, and resuming monitoring.

Because many of the same logs contain personal data (IP addresses, user identifiers, support activity), log retention and access also observe UK GDPR principles of data minimisation and storage limitation. No retention period has previously been set for certain log and support data; this policy requires that retention schedules be defined and documented within three months of adoption.

****6. Organisational Policies and Programmes**** (PCI DSS Requirement 12)

****Compliance intent****: Security is not only technical. Clear ownership, regular risk assessment, trained people, controlled suppliers and a ready incident-response capability are required so that the technical controls remain effective.

6.1 This Information Security Policy is the overarching policy. It is established, published, maintained and disseminated to all relevant personnel and to relevant vendors and business partners. It is reviewed at least annually and updated when business objectives or risks change.

6.2 Acceptable-use rules for end-user technologies (company laptops, approved software, personal devices) are documented and enforced. Personal devices may be used for email and calendar only; they are not permitted to reach systems connected to the CDE. This restriction is enforced by conditional-access policy.

6.3 Targeted risk analyses are performed and documented for every PCI DSS requirement that leaves frequency or process to the entity (including 7.2.5.1, 8.6.3, 10.4.2.1, 12.10.4.1 and others). Each analysis identifies the assets protected, the threats, the factors affecting likelihood and impact, the justification for the chosen frequency or process, and is reviewed at least annually.

6.4 An inventory of all system components in scope for PCI DSS is maintained and kept current. PCI DSS scope is confirmed at least annually and upon any significant change. Scope validation includes data flows, locations of account data, system components, segmentation, and third-party connections.

6.5 A formal security-awareness programme is in place. All personnel receive training on hire and at least annually. Training covers the information-security policy, phishing and social-engineering threats, acceptable use of end-user technologies, and the individual's role in protecting cardholder data. Multiple methods of communication are used. Personnel formally acknowledge that they have read and understood the policy at least annually. Role-specific training is provided to staff who handle disputes or hold administrative access. Completion is tracked; the previous year's 78 % completion rate is not acceptable and will be driven to 100 %.

6.6 Personnel who will have access to the CDE are screened, within the limits of UK law, before hire.

6.7 Third-party service providers (TPSPs)

- A single register of all TPSPs that share account data or could affect its security is maintained, with a description of the service each provides.
- Written agreements exist with every such TPSP and include acknowledgement that the TPSP is responsible for the security of any account data it possesses, stores, processes or transmits, or that could impact NorthPay's cardholder data.
- Due diligence is performed before engagement.
- PCI DSS compliance status of each TPSP is monitored at least annually.
- A clear matrix records which PCI DSS requirements are managed by the TPSP, which by NorthPay, and which are shared.

6.8 Incident response

An incident-response plan is maintained and ready for activation. It includes:

- roles, responsibilities and communication paths (including notification to the acquirer and, where required, the payment brands);
- specific containment and mitigation steps for different incident types;
- business-recovery and continuity procedures;
- data-backup processes;
- analysis of legal reporting requirements (including the UK GDPR 72-hour notification duty to the Information Commissioner's Office when the statutory criteria are met);
- coverage of all critical system components;
- reference to payment-brand incident-response procedures.

The plan is reviewed and tested at least annually. Specific personnel are designated to be available on a 24/7 basis. Those personnel receive appropriate and periodic training; the frequency is defined by targeted risk analysis.

The plan includes monitoring and response to alerts from security systems and is updated from lessons learned and industry developments.

Procedures exist for the discovery of any PAN stored where it is not expected (retrieval, secure deletion or migration into the defined CDE, determination of source, and remediation of the process gap).

Because a card-data incident may also constitute a personal-data breach under UK GDPR, the incident-response plan maps the dual notification paths (acquirer / payment brands and ICO) so that both clocks can be met.

7. Review and Enforcement

This policy is reviewed at least once every 12 months by the Information Security Manager and approved by the Chief Technology Officer. Material changes are communicated to all affected parties.

Failure to comply with this policy may result in disciplinary action up to and including dismissal, and, where appropriate, reporting to law-enforcement or regulatory authorities.

8. Related Documents

- Targeted risk analyses (maintained by Information Security Manager)
- Access-request and review records
- Third-party service-provider register and compliance matrix
- Incident-response plan
- Security-awareness training materials and acknowledgement records
- Acceptable-use rules for end-user technologies

End of Policy

E.4.5 P1c – ChatGPT – Control, no scenario (Prompt E)

Field	Record
Output ID	P1c

Field	Record
Model	ChatGPT
Prompt strategy	Control, no scenario (Prompt E)
Prompt used	Master Prompt E
Instrument files	Prompt Library.docx; Requirement Text Extract PCI DSS v4.0.1 Requirements 7, 8, 10, 12.docx; Scenario Brief NorthPay.docx; assembled prompt PROMPT-E_Control-no-scenario_ASSEMBLED_2026-08-16.txt
Model build / version	GPT-5.6 Sol (by Open AI)
Interface (app / API)	App
Date and time (BST)	16 Aug 2026 - 21:00 BST
Non-default settings	None
Refusal / truncation?	No

Verbatim output:

Information Security Policy

1. Purpose, Scope and Governance

PCI DSS Requirements: 12.1.1, 12.1.2, 12.1.3, 12.1.4

1.1 Purpose

This Information Security Policy establishes the organisational requirements for protecting system components, cardholder data (CHD), sensitive authentication data (SAD), and the cardholder data environment (CDE) through access control, authentication, logging and monitoring, security governance, risk management, security awareness, third-party oversight, and incident response.

1.2 Policy Establishment and Distribution

This Information Security Policy shall be established, published, maintained, and disseminated to all relevant personnel and to relevant vendors and business partners. ****[PCI DSS 12.1.1]****

1.3 Policy Review

This Policy shall be reviewed at least once every 12 months and updated as necessary to reflect changes to business objectives or risks to the environment. ****[PCI DSS 12.1.2]****

1.4 Information Security Responsibilities

Information security roles and responsibilities shall be clearly defined for all personnel. Personnel shall be made aware of and shall acknowledge their information security responsibilities. ****[PCI DSS 12.1.3]****

Responsibility for information security shall be formally assigned to a Chief Information Security Officer or another information-security-knowledgeable member of executive management. ****[PCI DSS 12.1.4]****

2. Access Control and Business Need to Know

****PCI DSS Requirement 7****

2.1 Access Control Governance

****PCI DSS Requirements: 7.1.1, 7.1.2****

2.1.1 Policies and Procedures

Security policies and operational procedures supporting access restrictions shall be documented, kept up to date, actively used, and known to all affected parties. ****[PCI DSS 7.1.1]****

2.1.2 Roles and Responsibilities

Roles and responsibilities for restricting access to system components and cardholder data shall be documented, assigned, and understood. ****[PCI DSS 7.1.2]****

2.2 Access Control Model

PCI DSS Requirements: 7.2.1, 7.2.2, 7.2.3

2.2.1 Access Principles

An access control model shall be defined and maintained. Access shall be granted according to:

1. The organisation's business and access needs.
2. The user's job classification and functions.
3. Access only to the system components and data resources necessary for those functions.
4. The least privileges necessary to perform the applicable job function, including differentiation between user and administrative privileges where applicable.

[PCI DSS 7.2.1]

2.2.2 User and Privileged Access

Access assigned to users, including privileged users, shall be based on job classification and function and limited to the least privileges necessary to perform assigned job responsibilities. **[PCI DSS 7.2.2]**

2.2.3 Approval

Required privileges shall be approved by authorized personnel before access is granted. **[PCI DSS 7.2.3]**

2.3 User Access Reviews

PCI DSS Requirement: 7.2.4

All user accounts and associated access privileges, including third-party and vendor accounts, shall be reviewed at least once every six months. Reviews shall verify that access remains appropriate for the user's job function, identify and address inappropriate access, and include management acknowledgement that retained access remains appropriate. **[PCI DSS 7.2.4]**

2.4 Application and System Accounts

PCI DSS Requirements: 7.2.5, 7.2.5.1

Application and system accounts and their associated access privileges shall:

1. Be assigned according to the least privileges necessary for system or application operability.
2. Be limited to the systems, applications, or processes that specifically require their use.

[PCI DSS 7.2.5]

Application and system account access and privileges shall be reviewed periodically at the frequency established through a targeted risk analysis conducted in accordance with Section 8.2 of this Policy. Reviews shall confirm that access remains appropriate for the function performed, address inappropriate access, and obtain management acknowledgement that retained access remains appropriate. **[PCI DSS 7.2.5.1, 12.3.1]**

2.5 Access to Stored Cardholder Data

PCI DSS Requirement: 7.2.6

User access to repositories of stored cardholder data shall occur through applications or other programmatic methods, with permitted access and actions determined according to user roles and least privilege. Direct access to or querying of repositories containing stored CHD shall be restricted to responsible administrators. **[PCI DSS 7.2.6]**

3. User Identification and Authentication

PCI DSS Requirement 8

3.1 Authentication Governance

PCI DSS Requirements: 8.1.1, 8.1.2

Security policies and operational procedures governing user identification and authentication shall be documented, kept current, actively used, and known to all affected parties. **[PCI DSS 8.1.1]**

Roles and responsibilities for identification and authentication activities shall be documented, assigned, and understood. **[PCI DSS 8.1.2]**

3.2 User Identification and Account Lifecycle

****PCI DSS Requirements: 8.2.1, 8.2.2, 8.2.4, 8.2.5, 8.2.6, 8.2.7, 8.2.8****

3.2.1 Unique Identification

Every user shall be assigned a unique ID before being permitted access to system components or cardholder data.
****[PCI DSS 8.2.1]****

3.2.2 Shared and Generic Accounts

Group, shared, generic IDs, or other shared authentication credentials shall be prohibited except where necessary for an exceptional circumstance. Where such use is necessary:

1. Use shall be prevented except for the exceptional circumstance.
2. Use shall be limited to the period required.
3. Business justification shall be documented.
4. Management shall explicitly approve the use.
5. The identity of the individual user shall be confirmed before access is granted.
6. Every action performed shall be attributable to an individual user.

****[PCI DSS 8.2.2]****

3.2.3 Account Changes

The addition, deletion, and modification of user IDs, authentication factors, and other identifier objects shall require appropriate authorization and shall be implemented only with the privileges specified in the documented approval.
****[PCI DSS 8.2.4]****

3.2.4 Terminated and Inactive Accounts

Access for terminated users shall be revoked immediately. ****[PCI DSS 8.2.5]****

Inactive user accounts shall be removed or disabled within 90 days of inactivity. ****[PCI DSS 8.2.6]****

3.2.5 Third-Party Remote Access Accounts

Accounts used by third parties to access, support, or maintain system components remotely shall be enabled only for the period in which they are required and disabled when not in use. Their use shall be monitored for unexpected activity. ****[PCI DSS 8.2.7]****

3.2.6 Session Inactivity

A user session that has been idle for more than 15 minutes shall require the user to re-authenticate before the terminal or session can be reactivated. ****[PCI DSS 8.2.8]****

3.3 Authentication Controls

****PCI DSS Requirements: 8.3.1, 8.3.3, 8.3.4, 8.3.5, 8.3.6, 8.3.7, 8.3.8, 8.3.9, 8.3.11****

3.3.1 Authentication Factors

All user and administrator access to system components shall be authenticated using at least one of the following:

1. Something the user knows, such as a password or passphrase.
2. Something the user has, such as a token device or smart card.
3. Something the user is, such as a biometric element.

****[PCI DSS 8.3.1]****

3.3.2 Authentication Factor Changes

A user's identity shall be verified before any authentication factor is modified. ****[PCI DSS 8.3.3]****

3.3.3 Invalid Authentication Attempts

User IDs shall be locked after no more than 10 invalid authentication attempts. Lockout shall remain in effect for at least 30 minutes or until the user's identity has been confirmed. ****[PCI DSS 8.3.4]****

3.3.4 Password and Passphrase Initialization

Where passwords or passphrases are used, they shall be set to a unique value for first-time use and following a reset and shall be changed immediately after first use. ****[PCI DSS 8.3.5]****

3.3.5 Password and Passphrase Complexity

Where passwords or passphrases are used, they shall:

1. Have a minimum length of 12 characters; where a system does not support 12 characters, the minimum shall be eight characters.
2. Contain both numeric and alphabetic characters.

[PCI DSS 8.3.6]

3.3.6 Password History

Users shall not be permitted to select a new password or passphrase that is the same as any of their previous four passwords or passphrases. **[PCI DSS 8.3.7]**

3.3.7 Authentication Guidance

Authentication policies and procedures shall be documented and communicated to all users and shall include:

1. Guidance for selecting strong authentication factors.
2. Guidance for protecting authentication factors.
3. Instructions not to reuse previously used passwords or passphrases.
4. Instructions to change passwords or passphrases upon suspicion or knowledge of compromise and instructions for reporting the incident.

[PCI DSS 8.3.8]

3.3.8 Single-Factor Password Authentication

Where passwords or passphrases are the only authentication factor used for user access, either:

1. Passwords or passphrases shall be changed at least once every 90 days; or
2. The security posture of accounts shall be dynamically analyzed and real-time access to resources automatically determined accordingly.

[PCI DSS 8.3.9]

3.3.9 Tokens, Smart Cards and Certificates

Physical or logical security tokens, smart cards, certificates, and similar authentication factors shall be assigned to individual users and shall not be shared. Physical and/or logical controls shall ensure that only the intended user can use the factor to gain access. **[PCI DSS 8.3.11]**

3.4 Multi-Factor Authentication

PCI DSS Requirements: 8.4.1, 8.4.2, 8.4.3

MFA shall be implemented for:

1. All non-console access into the CDE by personnel with administrative access. **[PCI DSS 8.4.1]**
2. All non-console access into the CDE. **[PCI DSS 8.4.2]**
3. All remote access originating outside the organisation's network that could access or impact the CDE. **[PCI DSS 8.4.3]**

3.5 Application and System Account Authentication

PCI DSS Requirements: 8.6.1, 8.6.2, 8.6.3

Where application or system accounts can be used for interactive login, interactive use shall be prevented except where required for an exceptional circumstance. Such use shall be time-limited, supported by documented business justification, explicitly approved by management, preceded by confirmation of the individual user's identity, and configured or managed so that every action is attributable to an individual user. **[PCI DSS 8.6.1]**

Passwords and passphrases for application or system accounts capable of interactive login shall not be hard coded in scripts, configuration/property files, or bespoke or custom source code. **[PCI DSS 8.6.2]**

Application and system account passwords or passphrases shall be changed periodically at the frequency established through a targeted risk analysis conducted in accordance with Section 8.2 of this Policy and upon suspicion or confirmation of compromise. Their complexity shall be appropriate to the frequency with which they are changed. **[PCI DSS 8.6.3, 12.3.1]**

4. Logging and Monitoring

PCI DSS Requirement 10

4.1 Logging and Monitoring Governance

PCI DSS Requirements: 10.1.1, 10.1.2

Security policies and operational procedures supporting logging and monitoring shall be documented, kept current, actively used, and known to all affected parties. **[PCI DSS 10.1.1]**

Roles and responsibilities for logging and monitoring activities shall be documented, assigned, and understood. **[PCI DSS 10.1.2]**

4.2 Protection of Audit Logs

PCI DSS Requirement: 10.3.1

Read access to audit log files shall be restricted to personnel with a job-related need. **[PCI DSS 10.3.1]**

4.3 Audit Log Reviews

PCI DSS Requirements: 10.4.1, 10.4.2, 10.4.2.1, 10.4.3

The following audit logs shall be reviewed at least once daily:

1. All security events.
2. Logs from all system components that store, process, or transmit CHD and/or SAD.
3. Logs from all critical system components.
4. Logs from servers and system components performing security functions, including network security controls, IDS/IPS, and authentication servers.

[PCI DSS 10.4.1]

Logs from other system components not covered above shall be reviewed periodically. **[PCI DSS 10.4.2]**

The frequency of these periodic reviews shall be established through a targeted risk analysis conducted in accordance with Section 8.2 of this Policy. **[PCI DSS 10.4.2.1, 12.3.1]**

Exceptions and anomalies identified through log review shall be addressed. **[PCI DSS 10.4.3]**

4.4 Audit Log Retention

****PCI DSS Requirement: 10.5.1****

Audit log history shall be retained for at least 12 months, with at least the most recent three months immediately available for analysis. ****[PCI DSS 10.5.1]****

4.5 Critical Security Control Failures

****PCI DSS Requirement: 10.7.3****

Failures of critical security control systems shall be responded to promptly. Response activities shall include:

1. Restoring security functions.
2. Identifying and documenting the duration of the failure, including start and end date and time.
3. Identifying and documenting the cause or causes and required remediation.
4. Identifying and addressing security issues arising during the failure.
5. Determining whether further actions are required.
6. Implementing controls to prevent recurrence of the cause.
7. Resuming monitoring of security controls.

****[PCI DSS 10.7.3]****

5. Acceptable Use of End-User Technologies

****PCI DSS Requirement: 12.2.1****

Documented acceptable-use policies for end-user technologies shall be implemented and shall include:

1. Explicit approval by authorized parties.
2. Defined acceptable uses of the technology.
3. A list of company-approved hardware and software products for employee use.

[PCI DSS 12.2.1]

6. Risk Management

PCI DSS Requirements: 12.3.1, 12.3.2, 12.3.3, 12.3.4

6.1 Targeted Risk Analysis

For every PCI DSS requirement specifying a targeted risk analysis, the organisation shall document an analysis containing:

1. Identification of the assets being protected.
2. Identification of the applicable threats.
3. Identification of factors contributing to the likelihood and/or impact of the threats being realized.
4. Analysis and justification demonstrating how the frequency or processes established by the organisation minimize the likelihood and/or impact of the threats.
5. Review of the targeted risk analysis at least once every 12 months to determine whether its results remain valid or whether an updated analysis is required.
6. Updated risk analyses where required by the annual review.

[PCI DSS 12.3.1]

6.2 Customized Approach Risk Analysis

For each PCI DSS requirement met using the customized approach, a targeted risk analysis shall be performed and shall include documented evidence addressing each applicable element specified in Appendix D: Customized Approach, including at minimum a controls matrix and risk analysis. The documented evidence shall be approved by senior management, and the targeted risk analysis shall be performed at least once every 12 months. **[PCI DSS 12.3.2]**

6.3 Cryptographic Technologies

Cryptographic cipher suites and protocols in use shall be documented and reviewed at least once every 12 months. The review shall include:

1. A current inventory of cipher suites and protocols, their purposes, and where they are used.
2. Active monitoring of industry trends concerning their continued viability.
3. A documented plan for responding to anticipated changes in cryptographic vulnerabilities.

[PCI DSS 12.3.3]

6.4 Hardware and Software Technologies

Hardware and software technologies in use shall be reviewed at least once every 12 months. Reviews shall include:

1. Analysis of whether technologies continue to receive security fixes from vendors promptly.
2. Analysis of whether technologies continue to support and do not preclude PCI DSS compliance.
3. Documentation of relevant industry announcements or trends, including vendor end-of-life announcements.
4. A senior-management-approved plan for remediating outdated technologies, including technologies for which vendors have announced end-of-life plans.

[PCI DSS 12.3.4]

7. PCI DSS Scope Management

PCI DSS Requirements: 12.5.1, 12.5.2

7.1 System Component Inventory

A current inventory of all system components within PCI DSS scope shall be maintained, including a description of each component's function or use. **[PCI DSS 12.5.1]**

7.2 Scope Validation

PCI DSS scope shall be documented and confirmed at least once every 12 months and following any significant change to the in-scope environment. Scope validation shall include, at minimum:

1. Identification of all data flows for payment stages, including authorization, capture, settlement, chargebacks, and refunds, as applicable, and all applicable acceptance channels, including card-present, card-not-present, and e-commerce.

2. Updating all applicable data-flow diagrams.

3. Identification of all locations where account data is stored, processed, or transmitted, including locations outside the currently defined CDE, applications processing CHD, transmissions between systems and networks, and file backups.

4. Identification of all system components within the CDE, connected to the CDE, or capable of impacting CDE security.

5. Identification of all segmentation controls and the environments from which the CDE is segmented, including justification for environments treated as out of scope.

6. Identification of all connections from third parties with access to the CDE.

7. Confirmation that all identified data flows, account data, system components, segmentation controls, and third-party connections with CDE access are included in scope.

****[PCI DSS 12.5.2]****

8. Security Awareness and Personnel Security

****PCI DSS Requirements: 12.6.1, 12.6.2, 12.6.3, 12.6.3.1, 12.6.3.2, 12.7.1****

8.1 Security Awareness Program

A formal security awareness program shall be implemented to ensure that all personnel understand the organisation's information security policies and procedures and their role in protecting cardholder data. ****[PCI DSS 12.6.1]****

The security awareness program shall be reviewed at least once every 12 months and updated as necessary to address new threats and vulnerabilities affecting CHD and/or SAD and to update information provided to personnel regarding their role in protecting cardholder data. ****[PCI DSS 12.6.2]****

8.2 Security Awareness Training

Personnel shall receive security awareness training upon hire and at least once every 12 months thereafter. Multiple methods of communication shall be used. Personnel shall acknowledge at least once every 12 months that they have read and understood the information security policy and procedures. ****[PCI DSS 12.6.3]****

Training shall include awareness of threats and vulnerabilities that could affect CHD and/or SAD, including phishing and related attacks and social engineering. ****[PCI DSS 12.6.3.1]****

Training shall also include awareness of the acceptable use of end-user technologies established under Section 5 of this Policy. ****[PCI DSS 12.6.3.2, 12.2.1]****

8.3 Personnel Screening

Potential personnel who will have access to the CDE shall be screened before hire, within the constraints of applicable local laws, to minimize the risk of attacks from internal sources. ****[PCI DSS 12.7.1]****

9. Third-Party Service Provider Management

****PCI DSS Requirement 12.8****

9.1 TPSP Inventory

A current list shall be maintained of all third-party service providers with which account data is shared or that could affect the security of account data. The list shall include a description of the services provided by each TPSP. ****[PCI DSS 12.8.1]****

9.2 Written Agreements

Written agreements shall be maintained with all TPSPs with which account data is shared or that could affect CDE security. Agreements shall include acknowledgement by each TPSP that it is responsible for the security of account data it possesses or otherwise stores, processes, or transmits on behalf of the organisation, or to the extent that the TPSP could impact the security of the organisation's CHD and/or SAD. ****[PCI DSS 12.8.2]****

9.3 TPSP Engagement and Due Diligence

An established process shall govern the engagement of TPSPs and shall include appropriate due diligence before engagement. ****[PCI DSS 12.8.3]****

9.4 PCI DSS Compliance Monitoring

A program shall be implemented to monitor each TPSP's PCI DSS compliance status at least once every 12 months. ****[PCI DSS 12.8.4]****

9.5 Responsibility Allocation

Information shall be maintained identifying which PCI DSS requirements are managed by each TPSP, which are managed by the organisation, and which responsibilities are shared between the TPSP and the organisation. **[PCI DSS 12.8.5]**

10. Security Incident Response

PCI DSS Requirement 12.10

10.1 Incident Response Plan

A security incident response plan shall be maintained and ready for immediate activation upon a suspected or confirmed security incident. The plan shall include, at minimum:

1. Roles, responsibilities, communication arrangements, and contact strategies for suspected and confirmed incidents, including notification of payment brands and acquirers.
2. Incident response procedures containing specific containment and mitigation activities for different incident types.
3. Business recovery and continuity procedures.
4. Data backup processes.
5. Analysis of legal requirements for reporting compromises.
6. Coverage and response procedures for all critical system components.
7. Reference to or inclusion of applicable payment-brand incident response procedures.

[PCI DSS 12.10.1]

10.2 Review and Testing

At least once every 12 months, the incident response plan shall be reviewed and updated as necessary and shall be tested against all elements specified in Section 10.1. **[PCI DSS 12.10.2]**

10.3 Incident Response Availability

Specific personnel shall be designated and available on a 24/7 basis to respond to suspected or confirmed security incidents. **[PCI DSS 12.10.3]**

10.4 Incident Response Training

Personnel responsible for responding to suspected and confirmed security incidents shall receive appropriate periodic training concerning their incident response responsibilities. **[PCI DSS 12.10.4]**

The frequency of this periodic training shall be established through a targeted risk analysis conducted in accordance with Section 8.2 of this Policy. **[PCI DSS 12.10.4.1, 12.3.1]**

10.5 Security Monitoring Alerts

The incident response plan shall include procedures for monitoring and responding to alerts from security monitoring systems, including:

1. Intrusion-detection and intrusion-prevention systems.
2. Network security controls.
3. Change-detection mechanisms for critical files.
4. Change- and tamper-detection mechanisms for payment pages.
5. Detection of unauthorized wireless access points.

[PCI DSS 12.10.5]

10.6 Continuous Improvement

The incident response plan shall be modified and evolved based on lessons learned and relevant industry developments. **[PCI DSS 12.10.6]**

10.7 Unexpected Storage of PAN

Incident response procedures shall be established and initiated when stored Primary Account Number (PAN) is detected in a location where it is not expected. Procedures shall include:

1. Determining appropriate action where PAN is discovered outside the CDE, including retrieval, secure deletion, and/or migration into the currently defined CDE, as applicable.
2. Identifying whether SAD is stored with the PAN.
3. Determining the source of the account data and how it came to be stored in the unexpected location.
4. Remediating data leaks or process gaps that caused the account data to be stored in the unexpected location.

[PCI DSS 12.10.7]

11. Policy Compliance and Maintenance

****PCI DSS Requirements: 7.1.1, 8.1.1, 10.1.1, 12.1.1, 12.1.2****

This Policy and the operational procedures established under it shall remain documented, current, in use, and known to affected parties. The organisation shall maintain and review this Policy in accordance with the governance requirements defined herein and shall update it as necessary to reflect changes to business objectives, risks, and the applicable environment. ****[PCI DSS 7.1.1, 8.1.1, 10.1.1, 12.1.1, 12.1.2]****

Control-run observations. The model did not ask for organisational context before answering, and did not invent an organisation of its own. It opened “This Information Security Policy establishes the organisational requirements for protecting system components, cardholder data (CHD), sensitive authentication data (SAD), and the cardholder data environment (CDE)...” and referred throughout to “the organisation”. Observations for Phase 5; not scored.

E.4.6 P2c – Grok – Control, no scenario (Prompt E)

Field	Record
Output ID	P2c
Model	Grok
Prompt strategy	Control, no scenario (Prompt E)
Prompt used	Master Prompt E
Instrument files	Prompt Library.docx; Requirement Text Extract PCI DSS v4.0.1 Requirements 7, 8, 10, 12.docx; Scenario Brief NorthPay.docx; assembled prompt PROMPT-E_Control-no-scenario_ASSEMBLED_2026-08-16.txt
Model build / version	Grok 4.5
Interface (app / API)	App
Date and time (BST)	16 Aug 2026 - 21:05 BST
Non-default settings	N/A

Field	Record
Refusal / truncation?	No

Verbatim output:

****Information Security Policy****

****1. Purpose and Scope****

1.1 This Information Security Policy establishes the framework for protecting system components and cardholder data in accordance with PCI DSS v4.0.1 Requirements 7, 8, 10, and 12.

1.2 This policy applies to all personnel, system components, and third-party service providers that store, process, or transmit cardholder data or that could impact the security of the cardholder data environment (CDE).

****2. Governance and Policy Management** (PCI DSS 12.1, 12.1.1, 12.1.2, 12.1.3, 12.1.4)**

2.1 An overall information security policy is established, published, maintained, and disseminated to all relevant personnel, vendors, and business partners.

2.2 The information security policy is reviewed at least once every 12 months and updated as needed to reflect changes to business objectives or risks to the environment.

2.3 The security policy clearly defines information security roles and responsibilities for all personnel. All personnel are aware of and acknowledge their information security responsibilities.

2.4 Responsibility for information security is formally assigned to a Chief Information Security Officer or other information security knowledgeable member of executive management.

****3. Access Control – Need to Know** (PCI DSS 7.1, 7.1.1, 7.1.2, 7.2, 7.2.1, 7.2.2, 7.2.3, 7.2.4, 7.2.5, 7.2.5.1, 7.2.6)**

3.1 Processes and mechanisms for restricting access to system components and cardholder data by business need to know are defined and understood.

3.2 All security policies and operational procedures identified in Requirement 7 are documented, kept up to date, in use, and known to all affected parties.

3.3 Roles and responsibilities for performing activities in Requirement 7 are documented, assigned, and understood.

3.4 An access control model is defined that grants access based on the entity's business and access needs, users' job classification and functions, and the least privileges required to perform a job function.

3.5 Access is assigned to users, including privileged users, based on job classification and function and the least privileges necessary to perform job responsibilities.

3.6 Required privileges are approved by authorized personnel.

3.7 All user accounts and related access privileges, including third-party/vendor accounts, are reviewed at least once every six months to ensure access remains appropriate based on job function. Inappropriate access is addressed, and management acknowledges that access remains appropriate.

3.8 All application and system accounts and related access privileges are assigned and managed based on the least privileges necessary for the operability of the system or application and are limited to the systems, applications, or processes that specifically require their use.

3.9 All access by application and system accounts and related access privileges is reviewed periodically at the frequency defined in the entity's targeted risk analysis performed according to Requirement 12.3.1. Access is confirmed to remain appropriate for the function being performed; inappropriate access is addressed; and management acknowledges that access remains appropriate.

3.10 All user access to query repositories of stored cardholder data is restricted via applications or other programmatic methods, with access and allowed actions based on user roles and least privileges. Only the responsible administrator(s) can directly access or query repositories of stored cardholder data.

****4. User Identification and Authentication**** (PCI DSS 8.1, 8.1.1, 8.1.2, 8.2, 8.2.1, 8.2.2, 8.2.4, 8.2.5, 8.2.6, 8.2.7, 8.2.8, 8.3, 8.3.1, 8.3.3, 8.3.4, 8.3.5, 8.3.6, 8.3.7, 8.3.8, 8.3.9, 8.3.11, 8.4, 8.4.1, 8.4.2, 8.4.3, 8.6, 8.6.1, 8.6.2, 8.6.3)

4.1 Processes and mechanisms for identifying users and authenticating access to system components are defined and understood.

4.2 All security policies and operational procedures identified in Requirement 8 are documented, kept up to date, in use, and known to all affected parties.

4.3 Roles and responsibilities for performing activities in Requirement 8 are documented, assigned, and understood.

4.4 All users are assigned a unique ID before access to system components or cardholder data is allowed.

4.5 Group, shared, or generic IDs or other shared authentication credentials are used only when necessary on an exception basis. Such use is prevented unless needed, limited to the time needed, supported by documented business justification, explicitly approved by management, preceded by confirmation of individual user identity, and ensures every action is attributable to an individual user.

4.6 Addition, deletion, and modification of user IDs, authentication factors, and other identifier objects are authorized with appropriate approval and implemented with only the privileges specified on the documented approval.

4.7 Access for terminated users is immediately revoked.

4.8 Inactive user accounts are removed or disabled within 90 days of inactivity.

4.9 Accounts used by third parties to access, support, or maintain system components via remote access are enabled only during the time period needed and disabled when not in use, and their use is monitored for unexpected activity.

4.10 If a user session has been idle for more than 15 minutes, the user is required to re-authenticate to re-activate the terminal or session.

4.11 All user access to system components for users and administrators is authenticated via at least one of the following authentication factors: something you know (password or passphrase), something you have (token device or smart card), or something you are (biometric element).

4.12 User identity is verified before modifying any authentication factor.

4.13 Invalid authentication attempts are limited by locking out the user ID after not more than 10 attempts and setting the lockout duration to a minimum of 30 minutes or until the user's identity is confirmed.

4.14 If passwords/passphrases are used as authentication factors, they are set to a unique value for first-time use and upon reset and are forced to be changed immediately after the first use.

4.15 If passwords/passphrases are used, they meet a minimum length of 12 characters (or eight characters if the system does not support 12) and contain both numeric and alphabetic characters.

4.16 Individuals are not allowed to submit a new password/passphrase that is the same as any of the last four passwords/passphrases used.

4.17 Authentication policies and procedures are documented and communicated to all users, including guidance on selecting strong authentication factors, protecting authentication factors, not reusing previously used

passwords/passphrases, and changing passwords/passphrases if there is suspicion or knowledge of compromise, together with instructions on how to report the incident.

4.18 If passwords/passphrases are used as the only authentication factor, they are changed at least once every 90 days, or the security posture of accounts is dynamically analyzed and real-time access to resources is automatically determined accordingly.

4.19 Where authentication factors such as physical or logical security tokens, smart cards, or certificates are used, they are assigned to an individual user and not shared, and physical and/or logical controls ensure only the intended user can use that factor to gain access.

4.20 Multi-factor authentication (MFA) is implemented for all non-console access into the CDE for personnel with administrative access, for all non-console access into the CDE, and for all remote access originating from outside the entity's network that could access or impact the CDE.

4.21 If accounts used by systems or applications can be used for interactive login, interactive use is prevented unless needed for an exceptional circumstance, limited to the time needed, supported by documented business justification, explicitly approved by management, preceded by confirmation of individual user identity, and ensures every action is attributable to an individual user.

4.22 Passwords/passphrases for any application and system accounts that can be used for interactive login are not hard coded in scripts, configuration/property files, or bespoke and custom source code.

4.23 Passwords/passphrases for any application and system accounts are changed periodically at the frequency defined in the entity's targeted risk analysis performed according to Requirement 12.3.1 and upon suspicion or confirmation of compromise, and are constructed with sufficient complexity appropriate for how frequently they are changed.

****5. Logging and Monitoring**** (PCI DSS 10.1, 10.1.1, 10.1.2, 10.3, 10.3.1, 10.4, 10.4.1, 10.4.2, 10.4.2.1, 10.4.3, 10.5, 10.5.1, 10.7, 10.7.3)

5.1 Processes and mechanisms for logging and monitoring all access to system components and cardholder data are defined and understood.

5.2 All security policies and operational procedures identified in Requirement 10 are documented, kept up to date, in use, and known to all affected parties.

5.3 Roles and responsibilities for performing activities in Requirement 10 are documented, assigned, and understood.

5.4 Read access to audit log files is limited to those with a job-related need.

5.5 The following audit logs are reviewed at least once daily: all security events; logs of all system components that store, process, or transmit cardholder data and/or sensitive authentication data; logs of all critical system components; and logs of all servers and system components that perform security functions.

5.6 Logs of all other system components are reviewed periodically. The frequency of these periodic reviews is defined in the entity's targeted risk analysis performed according to Requirement 12.3.1.

5.7 Exceptions and anomalies identified during the review process are addressed.

5.8 Audit log history is retained for at least 12 months, with at least the most recent three months immediately available for analysis.

5.9 Failures of any critical security control systems are responded to promptly, including restoring security functions; identifying and documenting the duration of the security failure; identifying and documenting the cause(s) of failure and required remediation; identifying and addressing any security issues that arose during the failure; determining whether further actions are required; implementing controls to prevent the cause of failure from reoccurring; and resuming monitoring of security controls.

****6. Risk Management** (PCI DSS 12.3, 12.3.1, 12.3.2, 12.3.3, 12.3.4)**

6.1 For each PCI DSS requirement that specifies completion of a targeted risk analysis, the analysis is documented and includes identification of the assets being protected, the threat(s) the requirement is protecting against, factors that contribute to the likelihood and/or impact of a threat being realized, resulting analysis that determines and justifies how the frequency or processes defined minimize the likelihood and/or impact of the threat, review of each targeted risk analysis at least once every 12 months, and performance of updated risk analyses when needed.

6.2 A targeted risk analysis is performed for each PCI DSS requirement met with the customized approach, including documented evidence detailing each element specified in Appendix D, approval by senior management, and performance at least once every 12 months.

6.3 Cryptographic cipher suites and protocols in use are documented and reviewed at least once every 12 months, including an up-to-date inventory with purpose and location of use, active monitoring of industry trends regarding continued viability, and documentation of a plan to respond to anticipated changes in cryptographic vulnerabilities.

6.4 Hardware and software technologies in use are reviewed at least once every 12 months, including analysis that the technologies continue to receive security fixes promptly, analysis that the technologies continue to support PCI DSS compliance, documentation of industry announcements or trends such as end-of-life plans, and documentation of a senior-management-approved plan to remediate outdated technologies.

****7. Scope Management** (PCI DSS 12.5, 12.5.1, 12.5.2)**

7.1 An inventory of system components that are in scope for PCI DSS, including a description of function/use, is maintained and kept current.

7.2 PCI DSS scope is documented and confirmed by the entity at least once every 12 months and upon significant change to the in-scope environment. Scoping validation includes identifying all data flows for payment stages and acceptance channels; updating all data-flow diagrams; identifying all locations where account data is stored, processed, and transmitted; identifying all system components in the CDE, connected to the CDE, or that could impact security of the CDE; identifying all segmentation controls and environments from which the CDE is segmented, including justification for out-of-scope environments; identifying all connections from third-party entities with access to the CDE; and confirming that all identified items are included in scope.

****8. Acceptable Use** (PCI DSS 12.2, 12.2.1)**

8.1 Acceptable use policies for end-user technologies are documented and implemented, including explicit approval by authorized parties, acceptable uses of the technology, and a list of products approved by the company for employee use, including hardware and software.

****9. Security Awareness** (PCI DSS 12.6, 12.6.1, 12.6.2, 12.6.3, 12.6.3.1, 12.6.3.2)**

9.1 A formal security awareness program is implemented to make all personnel aware of the entity's information security policy and procedures and their role in protecting cardholder data.

9.2 The security awareness program is reviewed at least once every 12 months and updated as needed to address new threats and vulnerabilities that may impact the security of cardholder data and/or sensitive authentication data or the information provided to personnel about their role.

9.3 Personnel receive security awareness training upon hire and at least once every 12 months. Multiple methods of communication are used. Personnel acknowledge at least once every 12 months that they have read and understood the information security policy and procedures.

9.4 Security awareness training includes awareness of threats and vulnerabilities that could impact the security of cardholder data and/or sensitive authentication data, including phishing and related attacks and social engineering.

9.5 Security awareness training includes awareness about the acceptable use of end-user technologies in accordance with Requirement 12.2.1.

****10. Personnel Screening**** (PCI DSS 12.7, 12.7.1)

10.1 Potential personnel who will have access to the CDE are screened, within the constraints of local laws, prior to hire to minimize the risk of attacks from internal sources.

****11. Third-Party Service Provider Management**** (PCI DSS 12.8, 12.8.1, 12.8.2, 12.8.3, 12.8.4, 12.8.5)

11.1 A list of all third-party service providers (TPSPs) with which account data is shared or that could affect the security of account data is maintained, including a description for each of the services provided.

11.2 Written agreements are maintained with all TPSPs with which account data is shared or that could affect the security of the CDE. Written agreements include acknowledgments from TPSPs that they are responsible for the security of account data the TPSPs possess or otherwise store, process, or transmit on behalf of the entity, or to the extent that the TPSP could impact the security of the entity's cardholder data and/or sensitive authentication data.

11.3 An established process is implemented for engaging TPSPs, including proper due diligence prior to engagement.

11.4 A program is implemented to monitor TPSPs' PCI DSS compliance status at least once every 12 months.

11.5 Information is maintained about which PCI DSS requirements are managed by each TPSP, which are managed by the entity, and any that are shared between the TPSP and the entity.

****12. Incident Response**** (PCI DSS 12.10, 12.10.1, 12.10.2, 12.10.3, 12.10.4, 12.10.4.1, 12.10.5, 12.10.6, 12.10.7)

12.1 An incident response plan exists and is ready to be activated in the event of a suspected or confirmed security incident. The plan includes roles, responsibilities, and communication and contact strategies, including notification of payment brands and acquirers; incident response procedures with specific containment and mitigation activities for different types of incidents; business recovery and continuity procedures; data backup processes; analysis of legal requirements for reporting compromises; coverage and responses of all critical system components; and reference or inclusion of incident response procedures from the payment brands.

12.2 At least once every 12 months, the security incident response plan is reviewed and the content updated as needed, and is tested, including all elements listed in Requirement 12.10.1.

12.3 Specific personnel are designated to be available on a 24/7 basis to respond to suspected or confirmed security incidents.

12.4 Personnel responsible for responding to suspected and confirmed security incidents are appropriately and periodically trained on their incident response responsibilities. The frequency of periodic training is defined in the entity's targeted risk analysis performed according to Requirement 12.3.1.

12.5 The security incident response plan includes monitoring and responding to alerts from security monitoring systems, including intrusion-detection and intrusion-prevention systems, network security controls, change-detection mechanisms for critical files, the change-and tamper-detection mechanism for payment pages, and detection of unauthorized wireless access points.

12.6 The security incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.

12.7 Incident response procedures are in place to be initiated upon the detection of stored PAN anywhere it is not expected, and include determining what to do if PAN is discovered outside the CDE (including its retrieval, secure deletion, and/or migration into the currently defined CDE); identifying whether sensitive authentication data is stored with PAN; determining where the account data came from and how it ended up where it was not expected; and remediating data leaks or process gaps that resulted in the account data being where it was not expected.

Control-run observations. The model did not ask for organisational context before answering, and did not invent an organisation of its own. It opened "This Information Security Policy establishes the framework for protecting system

components and cardholder data in accordance with PCI DSS v4.0.1 Requirements 7, 8, 10, and 12.” and used the phrase “the company” once. Observations for Phase 5; not scored.